

Security Analysis of NIST Key Derivation Using Pseudorandom Functions

Yaobin Shen¹, Lei Wang², and Dawu Gu²

¹ School of Informatics, Xiamen University, Xiamen, China
yaobin.shen@xmu.edu.cn

² Shanghai Jiao Tong University, Shanghai, China
wanglei_hb@sjtu.edu.cn, dwgu@sjtu.edu.cn

Abstract. Key derivation functions can be used to derive variable-length random strings that serve as cryptographic keys. They are integral to many widely-used communication protocols such as TLS, IPsec and Signal. NIST SP 800-108 specifies several key derivation functions based on pseudorandom functions such as CMAC and HMAC, that can be used to derive additional keys from an existing cryptographic key. This standard either explicitly or implicitly requests their KDFs to be variable output length pseudorandom function, collision resistant, and preimage resistant, which are also demanded by practical applications. Yet, since the publication of this standard dating back to the year of 2008, until now, there is no formal analysis to justify these security properties of KDFs.

In this work, we give the formal security analysis of key derivation functions in NIST SP 800-108. We show both positive and negative results regarding these key derivation functions. For KCTR-CMAC, KFB-CMAC, and KDPL-CMAC that are key derivation functions based on CMAC in counter mode, feedback mode, and double-pipeline mode respectively, we prove that all of them are secure variable output length pseudorandom functions and preimage resistant. We show that KFB-CMAC and KDPL-CMAC are collision resistant. While for KCTR-CMAC, we can mount collision attack against it that requires only six block cipher queries and can succeed with probability $1/4$. For KCTR-HMAC, KFB-HMAC, and KDPL-HMAC that are key derivation functions based on HMAC in modes, we show that all of them behave like variable output length pseudorandom functions. When the key of these key derivation functions is of variable length, they suffer from collision attacks. For the case when the key of these key derivation function is of fixed length and less than $d - 1$ bits where d is the input block size of the underlying compression function, we can prove that they are collision resistant and preimage resistant.

Keywords: Key derivation functions · CMAC · HMAC · Pseudorandom function

1 Introduction

Key derivation functions (KDFs) play an important role in many cryptographic protocols. They can be used to derive arbitrary amount of cryptographic keys from either a raw source containing some good amount of randomness but not necessarily uniform or a fixed-length cryptographic key. KDFs are integral to many widely-used communication protocols such as TLS, IPsec, or Signal to derive keys. There are two common methods to build a key derivation function. The first one follows a two-step paradigm called extract-then-expand as formalized by Krawczyk [17] and specified in NIST SP 800-56C [2]. The first step extracts a fixed-length pseudorandom key from a source that is entropic but not necessarily uniform. The second step takes this fixed-length key and expands it to generate a key of variable length. The second method simply expands a fixed-length key to a variable-length key. This method can be used to derive additional keys from an existing cryptographic key. Following the second method, NIST SP 800-108 [11] specifies several KDFs based on pseudorandom functions including HMAC [3], CMAC [14,13], and KMAC [15]. KDFs specified in NIST SP 800-108 can not only be used as an expansion component in a two-step key-derivation method, but can also be solely used to derive keys as general KDFs. Yet, until now, these KDFs lack a formal security analysis as explained below.

HISTORY OF NIST SP 800-108. KDFs in NIST SP 800-108 mainly uses the following procedure to derive variable-length keying material. Given a fixed-length K and a message M that contains the information of the derived keying material, the key derivation function $\text{KDF}(K, M)$ outputs a random string C of the desired length. The first version of NIST SP 100-108 was published in 2008 [9]. In this version, it specified three modes to build a KDF based on a pseudorandom function, including KDF in counter mode, KDF in feedback mode, and KDF in double-pipeline mode. The reason to specifying these modes is that the output of a pseudorandom function is typically of fixed length and cannot be solely used to generate variable-length strings. It used HMAC and CMAC as the underlying pseudorandom function in these modes. In the second version that is named as NIST SP 800-108r1 and published in 2022 [10], a KDF using KMAC [15] was included. Compared to HMAC and CMAC, KMAC is not equipped with any modes as it is based on a sponge function and its output can be of variable length. However, as acknowledged in [11, Appendix B], Arciszewski et al. revealed a serious key control security issue regarding KDFs based on CMAC in these three modes. Namely, for any n -bit value C , an entity that knows the key K can easily find a message M such that $\text{KDF}(K, M) = C$. Hence, this entity can force the output keying material to a pre-selected value as she wants. Obviously, the key control security can also be captured as the preimage resistance of a hash function. As a response to this key control attack, an updated version NIST SP 800-108r1-upd1 was published in 2024 [11]. In this updated version, specifications of KDFs based on CMAC in these three modes are revised, while other KDFs based on different pseudorandom functions remain the same as they do not suffer from this key control attack. The key control security is explicitly

written as a desirable security feature in this standard³. Yet, whether the revised version of KDFs based on CMAC or the other KDFs in this standard can provably achieve key control security remains open as currently we only know there are no existing attacks.

Recently, Bhaumik et al. [7] found that the context binding security requested by NIST SP 800-108r1-upd1⁴ can be formalized as the context-committing security for MAC that is essentially the same as the collision resistance of a hash function, and they show that CMAC is not context-committing secure. However, the context binding security of these KDFs still remain open, as neither the context-committing attack against CMAC works for KDFs based on CMAC in these three modes nor it say anything about the context binding security of other KDFs that are based on different pseudorandom functions.

Hence, so far we can see, besides the basic security property that a KDF should behave like a variable output length pseudorandom function (volPRF), it is also desirable that a KDF should have key control security and context binding security, where the former can be captured as preimage resistance and the later can be captured collision resistance (we use these two notions in the rest of this paper). The preimage resistance and collision resistance of KDFs are demanded in several important applications in practice, including TLS 1.3, IPSec, and key management service. In NIST standard reviewing project, the cryptography expert Mattsson from Ericsson Research [18] explicitly suggested that collision resistance and preimage resistance should be requirements for a key derivation function [18].

However, until now, there is no formal security analysis of NIST SP 800-108r1-upd1, even for the basic security as a variable output length pseudorandom function, despite of the fact that KDFs are widely-used. We have no idea whether KDFs in this standard can achieve the volPRF security, or being collision resistant, or being preimage resistant.

OUR CONTRIBUTIONS. In this paper, we give formal security analysis of NIST SP 800-108r1-upd1. We show both positive and negative results for the security of KDFs in this standard. A summary of our results is presented in Fig. 1. We mainly focus on KDFs based on fixed-output length pseudorandom functions equipped with modes to generate variable-output length strings, including KCTR-CMAC, KFB-CMAC, and KDPL-CMAC which are KDFs based on CMAC in counter mode, feedback mode, and double-pipeline mode respectively, and KCTR-HMAC, KFB-HMAC, and KDPL-HMAC which are KDFs based on HMAC in modes. As mentioned above, to resist against key control attack, there are subtle differences in the specification between KDFs based on CMAC and KDFs

³ The key control security provides assurance that "(even with knowledge of the input key K) no single party can manipulate the process in such a way as to force output keying material to a preselected value" [11, Section 6.7].

⁴ The context binding provides "assurance that all parties who (correctly) derive the keying material share the same understanding of who will access it and in which session it will be used. If those parties have different understandings, then they will derive different keying material" [11, Section 6.6].

Scheme	volPRF	Collision	Preimage	Analysis
KCTR-CMAC	$O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$	no	$O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$	Sec. 3.1
KCTR-HMAC	$O(\frac{q^2 b^2}{2^n})$	$O(\frac{p^2}{2^n})$	$O(\frac{p^2}{2^n})$	Sec. 3.2
KFB-CMAC	$O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$	$O(\frac{p^2}{2^n} + \frac{p^2 \ell}{2^n})$	$O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$	Sec. 4.1
KFB-HMAC	$O(\frac{q^2 b^2}{2^n} + \frac{q b^2}{2^n})$	$O(\frac{p^2}{2^n})$	$O(\frac{p^2}{2^n})$	Sec. 4.2
KDPL-CMAC	$O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$	$O(\frac{p^2}{2^n} + \frac{p^2 \ell}{2^n})$	$O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$	Sec. 5.1
KDPL-HMAC	$O(\frac{q^2 b^2}{2^n} + \frac{q b^2}{2^n})$	$O(\frac{p^2}{2^n})$	$O(\frac{p^2}{2^n})$	Sec. 5.2

Fig. 1: Summary of NIST SP 800-108r1-upd1 KDFs security. Here q denotes the number of queries to a key derivation function, with each query being of block length at most ℓ , b the output block length of a key derivation function, p the number of queries to the underlying primitive, n the block size of the underlying primitive. The collision resistance and preimage resistance bounds of KDFs based on HMAC only hold when the key is of fixed length and less than $d - 1$ bits.

based on HMAC, even in the case where they are equipped with the same mode. Hence, it requires to perform independent security analysis for these KDFs based on CMAC and HMAC.

For KDFs based on CMAC, there are a total of three different KDFs depending on the modes, including KCTR-CMAC, KFB-CMAC, and KDPL-CMAC. We prove that all of these three KDFs are a secure volPRF with the bound $O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$ by reducing the volPRF security of these three KDFs to the PRF security of the underlying CMAC, where n is the block size of the underlying block cipher, q the number of queries to the key derivation function with each query being of block length at most ℓ , b the output block length of the key derivation function. While CMAC itself is not collision resistant and preimage resistant, we prove that after being properly instantiated in modes, the resulting KDFs can be collision resistant and preimage resistant. Specially, we prove that all of these three KDFs based on CMAC are preimage resistant with the bound $O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$, where p denotes the number of queries to the underlying block cipher. We prove that KFB-CMAC and KDPL-CMAC are collision resistant with the bound $O(\frac{p^2}{2^n} + \frac{p^2 \ell}{2^n})$. However, for KCTR-CMAC that is the KDF based on CMAC in counter mode, we mount collision attack against it that requires six block cipher queries and the successful probability can be $1/4$. Thus, it shows distinction that KCTR-CMAC does not meet the collision resistance as required by this NIST standard and may not be used in scenarios where collision resistance is demanded.

For KDFs based on HMAC, we prove that all of KCTR-HMAC, KFB-HMAC, and KDPL-HMAC are a secure volPRF with the bound around $O(\frac{q^2 b^2}{2^n} + \frac{q b^2}{2^n})$, where n is the output block size of the underlying compression function, q the number of queries to the key derivation function, b the output block length of the key derivation function. Proofs are done by reducing the volPRF security

of KDFs to the PRF security of their underlying HMAC. Regarding collision resistance, we exhibit both negative and positive results. When the key of these KDFs is of variable length, we show collision attack against these KDFs that only requires two queries but can succeed with probability 1. This attack is due to the weak key pairs of HMAC when its key allows to have variable length that have been highlighted in previous attacks [12,21,7]. This sets an alert for these KDFs as the key of variable length is allowed in this standard (see [11, Section 6.2]). While for the case when the key is of fixed length and less than $d - 1$ bits where d is the size of input block of underlying compression function, we show that these KDFs are collision resistant and preimage resistant with the bound $O(\frac{p^2}{2^n})$, where p denotes the number of queries to the underlying compression function.

ORGANIZATION. We introduce relevant notations and security notions in Section 2. We give security analysis of KDFs based on CMAC and HMAC in counter mode in Section 3. We give security analysis of KDFs based on CMAC and HMAC in feedback mode in Section 4. Finally, we present security analysis of KDFs based on CMAC and HMAC in double-pipeline mode in Section 5. We conclude the paper in Section 6.

2 Preliminaries

NOTATION. Let ε denote the empty string. Let $\{0,1\}^n$ be the set of all n -bit strings and $\{0,1\}^*$ be the set of all finite bit strings including the empty string ε . For a finite set $\mathcal{X}$, let $X \leftarrow^s \mathcal{X}$ denote the uniform sampling from $\mathcal{X}$ and assigning the value to X . Let $|X|$ denote the length of string X . Let $X[i]$ denote the i -th bit of string X , and let $X[i : j]$ denote the substring of X from the i -th bit to the j -th bit both inclusively for $i \leq j$. Let $[i]_2$ denote the binary encoding of an integer i . Concatenation of strings X and Y is written as $X \parallel Y$ or simply XY . $X10^*$ denotes the padding that first appended with a single 1 and follow by as few 0 bits so that the length of string to be a multiple of n . Let $Y \leftarrow \mathcal{A}(X_1, \dots; r)$ denote running algorithm $\mathcal{A}$ with randomness r on inputs $X_1, \dots$ and assigning the output to Y . We let $Y \leftarrow^s \mathcal{A}(X_1, \dots)$ be the result of picking r at random and letting $Y \leftarrow \mathcal{A}(X_1, \dots; r)$. Let $\text{Perm}(n)$ denote the set of all permutations over $\{0,1\}^n$. Let $\text{Func}(\mathcal{X}, \mathcal{Y})$ denote the set of all functions from $\mathcal{X}$ to $\mathcal{Y}$.

PRP SECURITY. An adversary $\mathcal{A}$ is a probabilistic algorithm with access to one or more oracles. Let $\mathcal{A}^{O_1, O_2, \dots} = 1$ denote the event that an adversary $\mathcal{A}$ outputs 1 after interacting with oracles $O_1, O_2, \dots$. A block cipher $E : \{0,1\}^k \times \{0,1\}^n \rightarrow \{0,1\}^n$ is a family of permutations over $\{0,1\}^n$ indexed by a key $K \in \{0,1\}^k$. We write $E_K(\cdot)$ or $E(K, \cdot)$ as a permutation over $\{0,1\}^n$ for a key $K \in \{0,1\}^k$. We denote by $E_K^{-1}(\cdot)$ the inverse of $E_K(\cdot)$ for a fixed key K . Let $\pi \leftarrow^s \text{Perm}(n)$ be a random permutation. The advantage of $\mathcal{A}$ against the pseudorandom permutation (PRP) security of E is defined as

$$\text{Adv}_E^{\text{PRP}} = \left| \Pr \left[\mathcal{A}^{E_K(\cdot)} = 1 \right] - \Pr \left[\mathcal{A}^{\pi(\cdot)} = 1 \right] \right| ,$$

where K is selected uniformly at random from $\{0, 1\}^k$.

VARIABLE OUTPUT LENGTH PRF SECURITY. Let $F : \mathcal{K} \times \{0, 1\}^* \times \mathbb{N} \rightarrow \{0, 1\}^*$ be a keyed function whose output length is specified by the third input parameter. For example, for the input tuple (K, M, L) where $K \in \mathcal{K}$, $M \in \{0, 1\}^*$, and $L \in \mathbb{N}$, the function $F_K(M, L)$ outputs a string $Y \in \{0, 1\}^L$. Let $\text{Func}(\{0, 1\}^* \times \mathbb{N}, \{0, 1\}^*)$ denote the set of all functions from $\{0, 1\}^* \times \mathbb{N}$ to $\{0, 1\}^*$ whose output length is specified by the second parameter in the set $\mathbb{N}$. Let $\mathcal{R} \leftarrow_s \text{Func}(\{0, 1\}^* \times \mathbb{N}, \{0, 1\}^*)$ be a random function of variable output length whose output length is specified by the second parameter. The advantage of the adversary $\mathcal{A}$ against the variable output length PRF (volPRF) security of F is defined as

$$\text{Adv}_F^{\text{volprf}}(\mathcal{A}) = \left| \Pr \left[\mathcal{A}^{F_K(\cdot, \cdot)} = 1 \right] - \Pr \left[\mathcal{A}^{\mathcal{R}(\cdot, \cdot)} = 1 \right] \right| ,$$

where K is chosen uniformly at random from $\mathcal{K}$.

COLLISION RESISTANCE AND PREIMAGE RESISTANCE. Let $H : \mathcal{M} \rightarrow \mathcal{Y}$ be a hash function. We consider collision resistance and everywhere preimage resistance [20] as follows.

Definition 1. For any adversary $\mathcal{A}$, we define

$$\text{Adv}_H^{\text{coll}}(\mathcal{A}) = \Pr \left[(M, M') \leftarrow_s \mathcal{A} : M \neq M' \wedge H(M) = H(M') \right] .$$

Definition 2. For any adversary $\mathcal{A}$, we define

$$\text{Adv}_H^{\text{epre}}(\mathcal{A}) = \max_{Y \in \mathcal{Y}} \Pr \left[M \leftarrow_s \mathcal{A} : H(M) = Y \right] .$$

Note that in the rest of this paper, the hash function is either based on a block cipher or a compression function that will be modeled as an ideal cipher or a random oracle when considering collision resistance and preimage resistance. Hence, the randomness of the probability in definitions of collision resistance and preimage resistance comes from the ideal cipher or the random oracle.

3 Security Analysis of KDF in Counter Mode

3.1 Security Analysis of KCTR-CMAC

In this subsection, we present security analysis for the key derivation function KCTR-CMAC based on CMAC in counter mode. We first prove that KCTR-CMAC is a secure volPRF with the bound $O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$. We then show collision attack against KCTR-CMAC which illustrates that KCTR-CMAC is not collision resistant. Finally, we prove that KCTR-CMAC is preimage resistant with the bound $O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$.

SCHEME DESCRIPTION. The key derivation function KCTR-CMAC based on CMAC in counter mode is illustrated in Fig. 2. It takes as input a key K , two strings

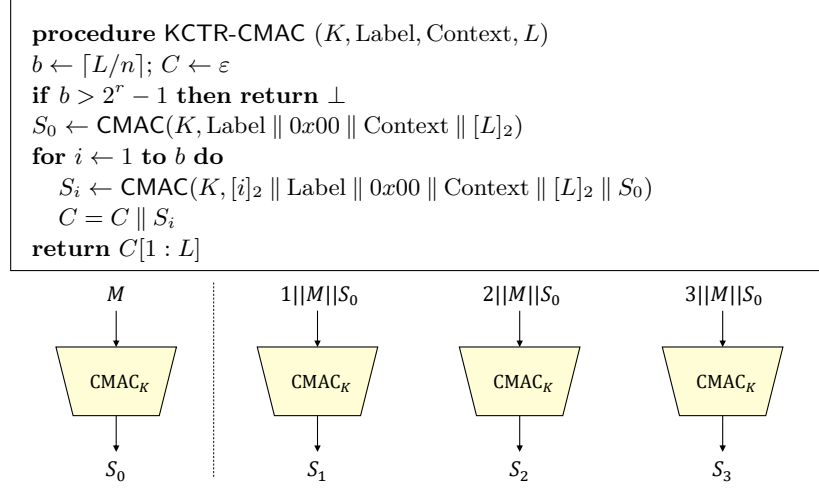


Fig. 2: The pseudocode definition of KCTR-CMAC in counter mode based on CMAC and its pictorial illustration for producing $3n$ -bit keying material $C = S_1 \parallel S_2 \parallel S_3$ where $M = \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$.

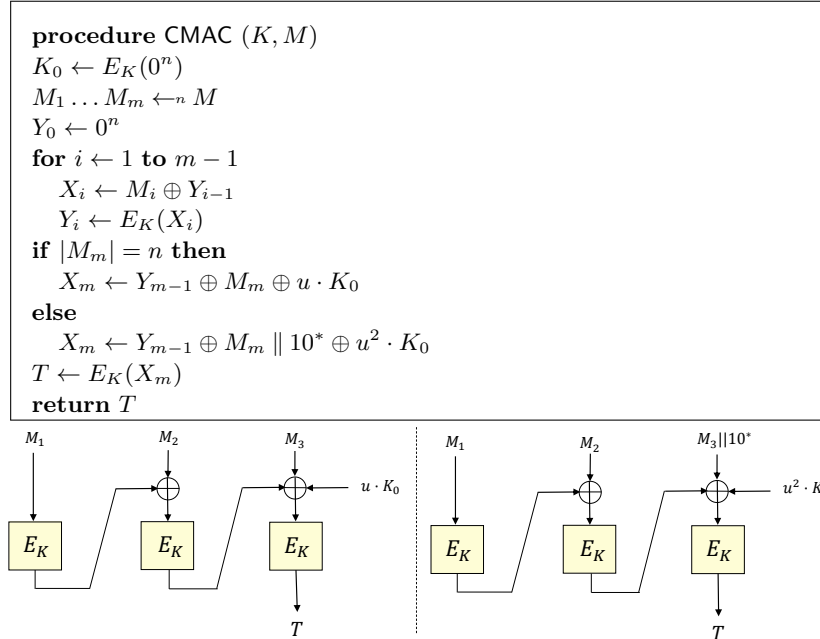


Fig. 3: The pseudocode definition of CMAC and its pictorial illustration for a three-block message M . Here u is some non-zero constant in $\mathbf{GF}(2^n)$.

called Label and Context⁵, an integer L that specifies the requested length

⁵ Here ‘Label’ is a bit string that identifies the purpose for the derived keying material and ‘Context’ is a bit string that contains the information related to the derived keying material as explained in [11].

in bits of the derived keying material, and outputs L bits of keying material by iterating the CMAC algorithm $\lceil L/n \rceil$ times and truncating the leftmost L bits. In each iteration of a CMAC execution, the fixed input data is the string $\text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2 \parallel S_0$ where $0x00$ is an all-zero octet and S_0 is defined as

$$S_0 = \text{CMAC}(K, \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2) .$$

The counter $[i]_2$ is prepended to the fixed input data and is encoded as a string of r bits. As required in NIST SP 800-108r1-upd1 [11], the length for each data field and their order shall be defined unambiguously. Hence, in the rest of this paper, besides the counter, we assume that the Label, the separation indicator $0x00$, the Context, and $[L]_2$ are represented with a specific length and in a specific order. The specification of CMAC is presented in Fig. 3 for the reference.

VOLPRF SECURITY. Assuming that the underlying block cipher E_K is a good PRP, the following theorem shows that KCTR-CMAC is a good volPRF. Recall that the volPRF security is defined in Section 2.

Theorem 1. *For any adversary $\mathcal{A}$ against the volPRF security of KCTR-CMAC that runs in time at most t , makes at most q queries, with each query being of block length at most ℓ and being of output block length at most b , we have*

$$\text{Adv}_{\text{KCTR-CMAC}}^{\text{volprf}}(\mathcal{A}) \leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \frac{20q^2(b+1)^2}{2^n} + \frac{23q(b+1)(\ell+2)^2}{2^n} ,$$

by assuming $q(b+1) \leq 2^{n/2-1}$ and $\ell+2 \leq 2^{n/4-0.5}$, where $\mathcal{B}$ is an adversary against the PRP security of the block cipher E that runs in time at most $t' = t + q(b+1)(\ell+3)t_E$ and makes at most $q(b+1)(\ell+3)$ block cipher queries where t_E denotes the running time for one computation of E .

Proof. Without loss of generality, we assume that the adversary $\mathcal{A}$ does not repeat a previous query as otherwise she will receive the same answer. We first replace the underlying block cipher E_K with a random permutation $\pi \leftarrow \$ \text{Perm}(n)$ and denote the resulting key derivation function by $\text{KCTR-CMAC}[\pi]$. From the standard argument, we have

$$\text{Adv}_{\text{KCTR-CMAC}[E]}^{\text{volprf}}(\mathcal{A}) \leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \text{Adv}_{\text{KCTR-CMAC}[\pi]}^{\text{volprf}}(\mathcal{A}) ,$$

where $\mathcal{B}$ is an adversary against the PRP security of block cipher E that makes at most $q(b+1)(\ell+3)$ queries and runs in times at most $t' = t + q(b+1)(\ell+3)t_E$.

Next, we replace the CMAC algorithm in KCTR-CMAC with a random function $f \leftarrow \$ \text{Func}(\{0,1\}^*, \{0,1\}^n)$ and denote the resulting key derivation function by $\text{KCTR-CMAC}[f]$. By using the results of [8,14,19] that show CMAC is a good PRF, we have

$$\text{Adv}_{\text{KCTR-CMAC}[\pi]}^{\text{volprf}}(\mathcal{A}) \leq \frac{20q^2(b+1)^2}{2^n} + \frac{23q(b+1)(\ell+2)^2}{2^n} + \text{Adv}_{\text{KCTR-CMAC}[f]}^{\text{volprf}}(\mathcal{A}) .$$

Here we use the state-of-the-art PRF security bound of CMAC in [8, Theorem 3.1] that is proved by assuming $q(b+1) \leq 2^{n/2-1}$ and $\ell+2 \leq 2^{n/4-0.5}$.

Finally, we show that the key derivation function $\text{KCTR-CMAC}[f]$ based on a random function f behaves exactly the same as a variable output length random function. For any query M to $\text{KCTR-CMAC}[f]$ as illustrated in the bottom of Fig. 2, the inputs $1 \parallel M \parallel S_0, 2 \parallel M \parallel S_0, \dots, b \parallel M \parallel S_0$ of the random function f to generate the keying material C are distinct due to the use of counter i . Hence, the corresponding outputs of f are independently random strings, there-with the derived keying material C being a L -bit random string as it is a L -bit truncation from $S_1 \parallel S_2 \parallel \dots \parallel S_b$. For any two distinct queries M and M' to $\text{KCTR-CMAC}[f]$, the inputs of the random function f to generate keying material C and C' are also distinct as $M \neq M'$. Therefore, the corresponding two derived keying material C and C' are independently random strings. Following this argument, we can obtain that for any q distinct queries to $\text{KCTR-CMAC}[f]$, the outputs of $\text{KCTR-CMAC}[f]$ are q independently random strings as the corresponding inputs of the random function f to produce these strings are distinct due to the use of counter and M being non-repeating in each query. Hence, we have

$$\text{Adv}_{\text{KCTR-CMAC}[f]}^{\text{volprf}}(\mathcal{A}) = 0 .$$

Summing over above equations, we obtain

$$\text{Adv}_{\text{KCTR-CMAC}}^{\text{volprf}}(\mathcal{A}) \leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \frac{20q^2(b+1)^2}{2^n} + \frac{23q(b+1)(\ell+2)^2}{2^n} ,$$

and complete the proof.

COLLISION ATTACK. We mount collision attack against KCTR-CMAC as follows. The goal of the adversary is to find a pair of $(K, \text{Label}, \text{Context}, L)$ and $(K', \text{Label}', \text{Context}', L')$ such that

$$\text{KCTR-CMAC}(K, \text{Label}, \text{Context}, L) = \text{KCTR-CMAC}(K', \text{Label}', \text{Context}', L')$$

with $(K, \text{Label}, \text{Context}, L) \neq (K', \text{Label}', \text{Context}', L')$. Obviously, L should equal to L' or otherwise two strings of different length will not collide. Fix K and K' such that $K = K'$. Assume $M = \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$ and $M' = \text{Label}' \parallel 0x00 \parallel \text{Context}' \parallel [L]_2$ that both have the length of $2n - r$ bits, and thus the length of $[i]_2 \parallel M \parallel S_0$ and $[i]_2 \parallel M' \parallel S'_0$ are both of $3n$ bits. Assume that $r = 1$ and $L = n$, namely that the counter is encoded as 1-bit string and KCTR-CMAC outputs only n -bit keying material by iterating the CMAC once with the counter $[1]_2$. Informally speaking, the intuition behind this attack is to construct a pair of message M and M' such that $S_0 = Y_2$ and $S'_0 = Y'_2$ where Y_2 and Y'_2 are outputs of the second last block cipher in CMAC respectively and result in a collision in the inputs to the last block cipher call. We now show in detail how the adversary can construct a pair of M and M' to violate the collision resistance of KCTR-CMAC . To find a collision on the output of KCTR-CMAC that is the same as $C[1:n] = C'[1:n]$, it requires the following equation holds:

$$\begin{aligned} & E_K(S_0 \oplus K_1 \oplus E_K(M[n:2n-1] \oplus E_K([1]_2 \parallel M[1:n-1]))) \\ &= E_K(S'_0 \oplus K_1 \oplus E_K(M'[n:2n-1] \oplus E_K([1]_2 \parallel M'[1:n-1]))) , \end{aligned}$$

where the subkey key K_1 is derived as $K_1 = u \cdot E_K(0^n)$ following the specification of CMAC [13,14]. After removing the outer block cipher call, the above equation becomes

$$\begin{aligned} & S_0 \oplus E_K(M[n : 2n-1] \oplus E_K([1]_2 \parallel M[1 : n-1])) \\ &= S'_0 \oplus E_K(M'[n : 2n-1] \oplus E_K([1]_2 \parallel M'[1 : n-1])) . \end{aligned} \quad (1)$$

If the adversary can find a pair of M and M' such that

$$S_0 = E_K(M[n : 2n-1] \oplus E_K([1]_2 \parallel M[1 : n-1])) \quad (2)$$

and

$$S'_0 = E_K(M'[n : 2n-1] \oplus E_K([1]_2 \parallel M'[1 : n-1])) , \quad (3)$$

then the equation (1) holds as both left part and right part of it become 0^n . The adversary can first construct M to satisfy the above condition as follows. The condition

$$S_0 = E_K(M[n : 2n-1] \oplus E_K([1]_2 \parallel M[1 : n-1]))$$

is the same as

$$\begin{aligned} & E_K((M[n+1 : 2n-1] \parallel 1) \oplus K_2 \oplus E_K(M[1 : n])) \\ &= E_K(M[n : 2n-1] \oplus E_K([1]_2 \parallel M[1 : n-1])) \end{aligned}$$

by writing down the computation of S_0 where $K_2 = u^2 \cdot E_K(0^n)$ is another subkey following the specification of CMAC. By removing the outer block cipher call, the above condition becomes

$$(M[n+1 : 2n-1] \parallel 1) \oplus K_2 \oplus E_K(M[1 : n]) = M[n : 2n-1] \oplus E_K([1]_2 \parallel M[1 : n-1]) .$$

The adversary can choose a value for $M[1 : n]$ to satisfy the format of M so that an all-zero octet $0x00$ following after the string ‘Label’ (we assume the length of ‘Label’ is less than or equal to $n-8$ bits here). After that, the adversary can compute the values of $E_K(M[1 : n])$ and $E_K([1]_2 \parallel M[1 : n-1])$. Let

$$\text{cst} = K_2 \oplus E_K(M[1 : n]) \oplus E_K([1]_2 \parallel M[1 : n-1]) .$$

The adversary then needs to compute the value for $M[n+1 : 2n-1]$ that should satisfy the following condition:

$$(M[n+1 : 2n-1] \parallel 1) \oplus M[n : 2n-1] = \text{cst} .$$

She can compute the value of $M[n+1 : 2n-1]$ one bit by one bit from the following equations:

$$\begin{aligned} M[n+1] \oplus M[n] &= \text{cst}[1] \\ M[n+2] \oplus M[n+1] &= \text{cst}[2] \\ &\vdots \\ M[2n-1] \oplus M[2n-2] &= \text{cst}[n-1] \\ 1 \oplus M[2n-1] &= \text{cst}[n] . \end{aligned}$$

Namely, from the last equation, she can obtain $M[2n-1]$ as $M[2n-1] = 1 \oplus \text{cst}[n]$. Then she can obtain $M[2n-2]$ as $M[2n-2] = M[2n-1] \oplus \text{cst}[n-1]$. Repeating this procedure, she can finally obtain $M[n+1] = M[n+2] \oplus \text{cst}[2]$ and $M[n] = M[n+1] \oplus \text{cst}[1]$. Note that the first bit $M[n]$ has been determined when the adversary chooses $M[1 : n]$, and the last $\lceil \log_2(n) \rceil$ bits $M[(2n - \lceil \log_2(n) \rceil) : 2n - 1]$ should be the encoding of L . Hence, there is probability that these bits should be consistent with the pre-determined values which is about $2^{-\lceil \log_2(n) \rceil - 1}$ by relying on the randomness of cst which is the xor sum of some outputs of block cipher E_K . At this stage, the adversary has constructed a message M such that the equation (2) holds. Following similar procedures, she can construct another message M' such that $M' \neq M$ by choosing $M'[1 : n] \neq M[1 : n]$ and makes the equation (3) hold with probability about $2^{-\lceil \log_2(n) \rceil - 1}$. Hence, the success probability of finding this pair of M and M' is about $2^{-2\lceil \log_2(n) \rceil - 2}$. If the block size of the underlying block cipher instantiated in CMAC is 128 bits like AES, then the success probability to find a collision against KCTR-CMAC becomes 2^{-16} .

Note that as specified in NIST SP 800-108r1-upd1 [11], the order of each data field can be defined as part of a KDF specification. The requirement is that the length for each data field and their order shall be defined unambiguously. Hence, if the fixed input data is defined in the order of $\text{Label} \parallel 0x00 \parallel [L]_2 \parallel \text{Context} \parallel S_0$, then the adversary may choose $M[1 : n]$ and $M'[1 : n]$ to satisfy the format imposed by $\text{Label} \parallel 0x00 \parallel [L]_2$ and $\text{Label}' \parallel 0x00 \parallel [L]_2$ (assume that the total length of each of these two strings is not greater than n bits). By doing so, the success probability of finding a collision against KCTR-CMAC is $1/4$ as there may not be format restriction in the strings Context and $\text{Context}'$. Hence, as a summary, the collision attack above requires six block cipher queries and can reach succeeding probability of $1/4$.

PREIMAGE RESISTANCE. For any fixed value $T \in \{0, 1\}^n$, we say an adversary finds a preimage against KCTR-CMAC if she outputs a pair of (K, M) such that $\text{KCTR-CMAC}(K, M)[1 : n] = T$. We suspect that although the derived keying material can allow to have more than n bits, the preimage resistance security may not be more than the case of n -bit output. Hence, we focus on the case when the image is of n bits. The following result illustrates that KCTR-CMAC is preimage resistant.

Theorem 2. *For any adversary $\mathcal{A}$ that makes at most p ideal-cipher queries to E and E^{-1} , we have*

$$\text{Adv}_{\text{KCTR-CMAC}}^{\text{pre}}(\mathcal{A}) \leq \frac{4p}{2^n} + \frac{2p^2\ell}{2^n},$$

by assuming $p \leq 2^{n-1}$ where ℓ is the maximum block length of a query to the key derivation function.

Proof. Let $\mathcal{A}$ be an adversary that aims at finding a preimage against the key derivation function KCTR-CMAC for any given image $T \in \{0, 1\}^n$. Namely, given an image $T \in \{0, 1\}^n$, the goal of the adversary is to find a preimage (K, M) such

that $\text{KCTR-CMAC}(K, M)[1 : n] = T$. The query to the key derivation function KCTR-CMAC is named as construction query, while the query to the block cipher E or E^{-1} is named as ideal cipher query. Assume that the adversary can make at most p queries to E and E^{-1} .

Fix an image $T \in \{0, 1\}^n$. Denote by P_i the event that the adversary find the preimage for T at the i -th construction query (K_i, M_i) , i.e., the event that $\text{KCTR-CMAC}(K_i, M_i)[1 : n] = T$.⁶ Let m be the bit length of the message M_i , and $\ell = \lceil m/n \rceil$. We consider the case of $m + r < n\ell$ where r is the bit length of the binary encoding of the counter i and n is the block size of the underlying block cipher. The other case of $m + r \geq n\ell$ can be analyzed similarly. The output of $\text{KCTR-CMAC}(K_i, M_i)[1 : n]$ is defined as $S_1^i = Y_{\ell+1}^i$, where internal block cipher calls among the computation of S_1^i are:

$$\begin{aligned}
B_0^i &= 0^n \\
A_j^i &= B_{j-1}^i \oplus M_i[n(j-1) + 1 : nj] \text{ for } 1 \leq j \leq \ell - 1 \\
A_\ell^i &= B_{\ell-1}^i \oplus M_i[n(\ell-1) + 1 : m] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) \\
B_j^i &= E_{K_i}(A_j^i) \text{ for } 1 \leq j \leq \ell \\
S_0^i &= B_\ell^i \\
Y_0^i &= 0^n \\
X_1^i &= Y_0^i \oplus [1]_r \parallel M_i[1 : n - r] \\
X_j^i &= Y_{j-1}^i \oplus M_i[n(j-1) - r + 1 : nj - r] \text{ for } 2 \leq j \leq \ell - 1 \\
X_\ell^i &= Y_{\ell-1}^i \oplus M_i[n(\ell-1) - r + 1 : m] \parallel S_0^i[1 : n\ell - m - r] \\
X_{\ell+1}^i &= Y_\ell^i \oplus S_0^i[n\ell - m - r + 1 : n] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) \\
Y_j^i &= E_{K_i}(X_j^i) \text{ for } 1 \leq j \leq \ell + 1 .
\end{aligned}$$

We call the chain to produce the value S_0^i as the first **CMAC** chain, and the chain to produce the value S_1^i as the second **CMAC** chain. We proceed to analyze the preimage security by considering the type of ideal cipher queries to build these two **CMAC** chains.

If both of $(K_i, A_\ell^i, B_\ell^i)$ and $(K_i, X_\ell^i, Y_\ell^i)$ are forward block cipher queries, then the probability that $Y_\ell^i \oplus B_\ell^i[n\ell - m - r + 1 : n] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) = E_{K_i}^{-1}(T)$ is at most $1/(2^n - p)$ as Y_ℓ^i is distributed uniformly at random in a set of size at least $2^n - p$. One exception is when $Y_\ell^i = B_\ell^i[n\ell - m - r + 1 : n] \parallel 10^*$ as shown in the collision attack against **KCTR-CMAC**. Yet, in this case, it requires that $u^2 \cdot E_{K_i}(0^n) = E_{K_i}^{-1}(T)$ which happens with probability at most $1/(2^n - p)$ for a given image T . Hence, summing over at most $\binom{p}{2}$ different pairs of $(K_i, A_\ell^i, B_\ell^i)$

⁶ Note that although we consider event P_i at the i -th construction query, the following analysis explicitly considers ideal cipher queries inside this construction query. Eventually, if the adversary finds the preimage for a given image T , it will anyway form a construction query (K_i, M_i) from ideal cipher queries such that $\text{KCTR-CMAC}(K_i, M_i)[1 : n] = T$.

and $(K_i, X_\ell^i, Y_\ell^i)$, we have

$$\sum_{i=1}^q \Pr[\mathbf{P}_i] \leq \frac{p(p-1)}{2(2^n - p)} \leq \frac{p^2}{2^n}$$

by assuming $p \leq 2^{n-1}$.

If at least one of $(K_i, A_\ell^i, B_\ell^i)$ and $(K_i, X_\ell^i, Y_\ell^i)$ is a backward block cipher query, then without loss of generality, we assume that $(K_i, A_\ell^i, B_\ell^i)$ is a backward block cipher query. The other case that $(K_i, X_\ell^i, Y_\ell^i)$ is a backward query can be analyzed similarly. We consider different cases depending on whether the preceding block cipher call is a forward query or not. If the preceding block cipher call $(K_i, A_{\ell-1}^i, B_{\ell-1}^i)$ is a forward block cipher query, then $M_i[n(\ell-1)+1 : m] \parallel 10^* = A_\ell^i \oplus B_{\ell-1}^i \oplus u^2 \cdot E_{K_i}(0^n)$ is distributed uniformly at random in a set of size at least $2^n - \max\{p_{i,\ell-1}, p_{i,\ell}\}$ where $p_{i,j}$ denotes the total number of ideal cipher queries at the j -th block cipher call in this CMAC chain. If the preceding block cipher call $(K_i, A_{\ell-1}^i, B_{\ell-1}^i)$ is a backward block cipher query, then the adversary can set $B_{\ell-1}^i = A_\ell^i \oplus M_i[n(\ell-1)+1 : m] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n)$ and does the backward query to obtain $A_{\ell-1}^i$. We can repeat this argument until some preceding block cipher call (K_i, A_j^i, B_j^i) is a forward query for $1 \leq j \leq \ell-1$. In this case, the message block $M_i[nj+1 : n(j+1)] = A_{j+1}^i \oplus B_j^i$ is uniformly distributed in a set of size at least $2^n - \max\{p_{i,j}, p_{i,j+1}\}$ as A_{j+1}^i is uniformly distributed in a set of size at least $2^n - p_{i,j+1}$ and B_j^i is uniformly distributed in a set of size at least $2^n - p_{i,j}$. In the case that all of preceding block cipher calls are backward queries, then the first message block $M_i[1 : n]$ will be distributed uniformly at random in a set of size at least $2^n - p_{i,1}$ due to the randomness of the output of $E_{K_i}^{-1}(B_1^i)$. Let $M_i[nc+1 : n(c+1)]$ be this random message block where $0 \leq c < \ell-1$. Note that the case when the random message block is $M_i[n(\ell-1)+1 : m] \parallel 10^*$ can be analyzed similarly, and in the following we focus on the more general case of $M_i[nc+1 : n(c+1)]$ with $0 \leq c < \ell-1$. Without loss of generality, we assume that all of message blocks including this random message block has been determined during the computation of the first CMAC chain. We then analyze the influence of this random message block on the second CMAC chain. This message block may spread into two block cipher calls in the second CMAC chain. If $c = 0$, then it will spread into two block cipher calls with input

$$X_{c+1}^i = Y_c^i \oplus [1]_2 \parallel M_i[1 : n-r]$$

and

$$X_{c+2}^i = Y_{c+1}^i \oplus M_i[n-r+1 : 2n-r] .$$

If $c > 0$, then it will spread into two block cipher calls with inputs

$$X_{c+1}^i = Y_c^i \oplus M_i[nc-r+1 : n(c+1)-r]$$

and

$$X_{c+2}^i = Y_{c+1}^i \oplus M_i[n(c+1)-r+1 : n(c+2)-r] .$$

Let E_1 be the event that X_{c+1}^i hits the previous inputs of the block cipher E_{K_i} , E_2 the event that X_{c+2}^i hits the previous inputs of the block cipher E_{K_i} . Then we have

$$\begin{aligned}\Pr[E_2] &= \Pr[E_2 \wedge E_1] + \Pr[E_2 \wedge \overline{E_1}] \\ &= \Pr[E_2 \mid E_1] \cdot \Pr[E_1] + \Pr[E_2 \mid \overline{E_1}] \cdot \Pr[\overline{E_1}] \\ &\leq \Pr[E_2 \mid E_1] \cdot \Pr[E_1] + \Pr[E_2 \mid \overline{E_1}] \end{aligned} \quad (4)$$

as $\Pr[\overline{E_1}] \leq 1$. We first analyze the probability of the first term on the right side of this equation. As all of message blocks have been determined in the first CMAC chain, we can use message blocks $[1]_2 \parallel M_i[1 : n-r]$, $M_i[n-r+1 : 2n-r]$, $\dots$, $M_i[n(c-1)-r+1 : nc-r]$ to compute the chain that reaches the output Y_c^i . Let $\text{Dom}(E_{K_i}^j)$ denote the set of inputs of queried block cipher calls E_{K_i} and outputs of queried block cipher calls $E_{K_i}^{-1}$ at the j -th call to the block cipher E_{K_i} in the second CMAC chain. Denote by $\tilde{p}_{i,j}$ the size of $\text{Dom}(E_{K_i}^j)$. Let

$$\begin{aligned}D_1 &= \{X[r+1 : n] \mid X \in \text{Dom}(E_{K_i}^c) \\ &\quad \wedge X[1 : r] = Y_c^i[1 : r] \oplus M_i[nc-r+1 : nc]\} .\end{aligned}$$

Then event E_1 requires that

$$M_i[nc+1 : n(c+1)-r] \oplus Y_c^i[r+1 : n] \in D_1 .$$

Let

$$\begin{aligned}D_2 &= \{X[1 : r] \mid X \in \text{Dom}(E_{K_i}^{c+1}) \\ &\quad \wedge X[r+1 : n] = Y_{c+1}^i[r+1 : n] \oplus M_i[n(c+1)+1 : n(c+2)-r]\} .\end{aligned}$$

Conditioned on that event E_1 happens, event E_2 requires that

$$M_i[n(c+1)-r+1 : n(c+1)] \oplus Y_{c+1}^i[1 : r] \in D_2 .$$

As $\text{Dom}(E_{K_i}^c) \subset \text{Dom}(E_{K_i}^{c+1})$ (without loss of generality, we assume that the c -th block cipher call is made before the $(c+1)$ -th block cipher call in the second CMAC chain), we have

$$|D_1| + |D_2| \leq |\text{Dom}(E_{K_i}^{c+1})| + 1 = \tilde{p}_{i,c+1} + 1 ,$$

as there is only one possible element in $\text{Dom}(E_{K_i}^{c+1})$ that can both lie in the set of D_1 and D_2 , namely the only potential value is X where $X[1 : r] = Y_c^i[1 : r] \oplus M_i[nc-r+1 : nc]$ and $X[r+1 : n] = Y_{c+1}^i[r+1 : n] \oplus M_i[n(c+1)+1 : n(c+2)-r]$. Hence, we have

$$\Pr[E_2 \wedge E_1] \leq \frac{\tilde{p}_{i,c+1} + 1}{2^n - p_{i,c+1}} ,$$

as the message block $M_i[nc + 1 : n(c + 1)]$ is distributed uniformly at random in a set of size at least $2^n - p_{i,c+1}$. We proceed to analyze the second term on the right side of the equation (4). Conditioned on that event E_1 does not happen, the value Y_{c+1}^i is distributed uniformly at random in a set of size at least $2^n - \tilde{p}_{i,c+1}$, as it is the output of $E_{K_i}(X_{c+1}^i)$. Hence, we have

$$\Pr[E_2 \mid \bar{E}_1] \leq \frac{\tilde{p}_{i,c+1}}{2^n - \tilde{p}_{i,c+1}}.$$

Therefore,

$$\Pr[E_2] \leq \frac{\tilde{p}_{i,c+1} + 1}{2^n - p_{i,c+1}} + \frac{\tilde{p}_{i,c+1}}{2^n - \tilde{p}_{i,c+1}}.$$

We then continue to analyze subsequent block cipher calls. Denote by $\text{bcoll}_{i,c+j}$ the event that $X_{c+j}^i = Y_{c+j-1}^i \oplus M_i[n(c + j - 1) - r + 1 : n(c + j) - r]$ hits previous inputs of the block cipher E_{K_i} for $3 \leq j \leq \ell + 1 - c$. Then we have $\Pr[\text{bcoll}_{i,c+j}] \leq \tilde{p}_{i,c+j-1}/(2^n - \tilde{p}_{i,c+j-1})$. Let $\text{Bcoll}_i = E_2 \vee (\bigvee_{j=3}^{\ell+1-c} \text{bcoll}_{i,c+j})$. Conditioned on that the event Bcoll_i does not happen, S_1^i is distributed uniformly at random in a set of size at least $2^n - \tilde{p}_{i,\ell+1}$. Thus, the probability of the preimage event P_i can be bounded by

$$\begin{aligned} \Pr[P_i] &\leq \Pr[P_i \mid \overline{\text{Bcoll}_i}] + \Pr[\text{Bcoll}_i] \\ &\leq \frac{1}{2^n - \tilde{p}_{i,\ell+1}} + \Pr[E_2 \vee (\bigvee_{j=3}^{\ell+1-c} \text{bcoll}_{i,\ell+c+j})] \\ &\leq \frac{1}{2^n - \tilde{p}_{i,\ell+1}} + \Pr[E_2] + \Pr[\text{bcoll}_{i,c+3}] \\ &\quad + \sum_{j=4}^{\ell+1-c} \Pr[\text{bcoll}_{i,c+j} \mid \overline{\text{bcoll}_{i,c+3}} \wedge \cdots \wedge \overline{\text{bcoll}_{i,c+j-1}} \wedge \bar{E}_2] \\ &\leq \frac{4}{2^n} + \frac{2p\ell}{2^n}, \end{aligned}$$

by assuming $p_{i,j}, \tilde{p}_{i,j} \leq p \leq 2^{n-1}$. Summing over at most $q \leq p$ construction queries, we have

$$\sum_{i=1}^q \Pr[P_i] \leq \frac{4p}{2^n} + \frac{2p^2\ell}{2^n}.$$

As $p^2/2^n \leq 4p/2^n + 2p^2\ell/2^n$, we have

$$\text{Adv}_{\text{KCTR-CMAC}}^{\text{epre}}(\mathcal{A}) \leq \frac{4p}{2^n} + \frac{2p^2\ell}{2^n}$$

that completes the proof.

3.2 Security Analysis of KCTR-HMAC

In this subsection, we give security analysis of key derivation function KCTR-HMAC based on HMAC in counter mode. We prove that KCTR-HMAC is a secure volPRF

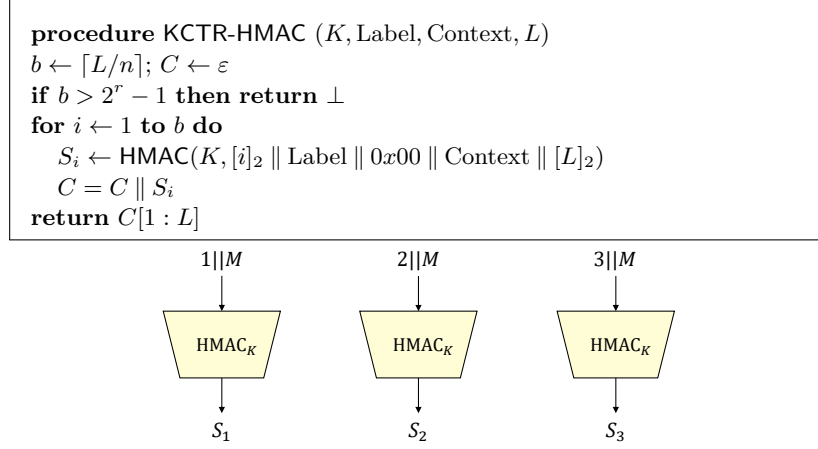


Fig. 4: The pseudocode definition of KCTR-HMAC in counter mode based on HMAC and its pictorial illustration for producing $3n$ -bit keying material $C = S_1 \parallel S_2 \parallel S_3$ where $M = \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$.



Fig. 5: The definition of h^* .

with the bound $O(\frac{q^2 b^2}{2^n})$. We show that KCTR-HMAC is collision resistant and preimage resistant both with the bound $O(\frac{p^2}{2^n})$ when the key is of fixed length and less than $d-1$ bits. We also show collision attack against KCTR-HMAC when the key is of variable length.

SCHEME DESCRIPTION. The key derivation function KCTR-HMAC is the same as KCTR-CMAC, except that the underlying PRF is replaced with HMAC, and the fixed input data is simplified from $\text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2 \parallel S_0$ to $\text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$, namely the string S_0 is removed. See Fig. 4 for pseudocode specification and pictorial illustration of KCTR-HMAC.

VOLPRF SECURITY. Let $h : \{0, 1\}^n \times \{0, 1\}^d \rightarrow \{0, 1\}^n$ be a compression function. Let pad be the padding function such that $M^* = M \parallel \text{pad}(|M|) \in (\{0, 1\}^n)^+$ for any string M . The cryptographic hash function H associated to h is defined as $H(M) = h^*(iv, M^*)$, where iv is a n -bit initial value that is fixed as part of the description of hash function H and M is a string of arbitrary length such that $M^* = M \parallel \text{pad}(|M|)$. The pseudocode description of h^* is given in Fig. 5.

Then $\text{HMAC} : \{0, 1\}^* \times \{0, 1\}^* \rightarrow \{0, 1\}^n$ is defined as

$$\text{HMAC}(K, M) = H(K' \oplus \text{opad} \parallel H(K' \oplus \text{ipad} \parallel M)) ,$$

where opad and ipad are two distinct d -bit constant strings, $K' = H(K) \parallel 0^{d-n}$ if K is larger than the block size of h and $K' = K \parallel 0^{d-|K|}$ if K is less than or equal to the block size of h .

Let $\bar{h} : \{0, 1\}^d \times \{0, 1\}^n \rightarrow \{0, 1\}^n$ be the dual of h , namely $\bar{h}(x, y) = h(y, x)$. The assumption that h is a PRF when keyed by its data input is equivalent to the assumption that $\bar{h}$ is a PRF. We say that h is a secure dual-PRF if both h and $\bar{h}$ are a secure PRF. We will show that KCTR-HMAC is a secure volPRF as long as h is a dual-PRF and $\bar{h}$ is a PRF against an appropriate class of related key attacks. Before that, we recall the formal definition of related key security from [4].

A related-key attack on $\bar{h} : \{0, 1\}^d \times \{0, 1\}^n \rightarrow \{0, 1\}^n$ is parameterized by a set of mappings $\Phi : \{0, 1\}^d \rightarrow \{0, 1\}^d$. Let the related key function $\text{RK} : \Phi \times \{0, 1\}^d \rightarrow \{0, 1\}^d$ be $\text{RK}(\phi, K) = \phi(K)$ where $\phi \in \Phi$ and $K \in \{0, 1\}^d$. A related-key attack adversary against $\bar{h}$ may make an oracle query of the form (ϕ, x) where $\phi \in \Phi$ and $x \in \{0, 1\}^c$. Let $\text{Func}(\{0, 1\}^d \times \{0, 1\}^n, \{0, 1\}^n)$ denote the set of all functions from $\{0, 1\}^d \times \{0, 1\}^n$ to $\{0, 1\}^n$. The rkaPRF advantage is defined by

$$\text{Adv}_{\bar{h}, \Phi}^{\text{rkaPRF}}(\mathcal{A}) = \left| \Pr[\mathcal{A}^{\bar{h}(\text{RK}(\cdot, K), \cdot)} = 1] - \Pr[\mathcal{A}^{G(\text{RK}(\cdot, K), \cdot)} = 1] \right| ,$$

where K is chosen uniformly at random from $\{0, 1\}^d$ and G is chosen uniformly at random from $\text{Func}(\{0, 1\}^d \times \{0, 1\}^n, \{0, 1\}^n)$. The related key function set of interest for HMAC is

$$\Phi_{\text{zio}, e} : \{0, \dots, d\} \times \{\text{opad}, \text{ipad}\} \times \{0, 1\}^d \rightarrow \{0, 1\}^d \cup \{\perp\}$$

defined as follows: on inputs $i \in \{0, \dots, d\}$, $\text{const} \in \{\text{opad}, \text{ipad}\}$, and $K \in \{0, 1\}^d$, it returns $(K[1 : i] \parallel 0^{d-i}) \oplus \text{const}$ if $i \geq e$ and $\perp$ otherwise. Namely, $\Phi_{\text{zio}, e}$ overwrites the right $(d - i)$ bits of the key K with zeros, and then XORs the result with either opad or ipad .

Theorem 3. *For any adversary $\mathcal{A}$ against the volPRF security of KCTR-HMAC that runs in time at most t , makes at most q queries, with each query being of block length at most ℓ and being of output block length at most b , we have*

$$\text{Adv}_{\text{KCTR-HMAC}}^{\text{volprf}}(\mathcal{A}) \leq (\ell+4) \text{Adv}_h^{\text{prf}}(\mathcal{A}_1) + \text{Adv}_{\bar{h}}^{\text{prf}}(\mathcal{A}_2) + \text{Adv}_{\Phi_{\text{zio}, e}, \bar{h}}^{\text{rkaPRF}}(\mathcal{B}) + \frac{qb(qb-1)}{2^{n+1}} .$$

Adversaries $\mathcal{A}_1$ and $\mathcal{A}_2$ are against the PRF security of h and $\bar{h}$ respectively, where $\mathcal{A}_1$ makes at most qb queries and $\mathcal{A}_2$ makes one query. Adversary $\mathcal{B}$ makes two queries. The running times of adversaries $\mathcal{A}_1$, $\mathcal{A}_2$ and $\mathcal{B}$ are about the same as that of $\mathcal{A}$.

Proof. Let $\mathcal{A}$ be an adversary against the volPRF security of KCTR-HMAC. We first replace HMAC with a random function $f \leftarrow \text{Func}(\{0, 1\}^* \times \{0, 1\}^*, \{0, 1\}^n)$ in KCTR-HMAC and denote the key derivation function by $\text{KCTR-HMAC}[f]$. Using the result of [1, Theorem 8] that shows HMAC is a good PRF under the assumption of dual-PRF security of h and rka-PRF security of $\bar{h}$, we have

$$\begin{aligned} \text{Adv}_{\text{KCTR-HMAC}}^{\text{volprf}}(\mathcal{A}) &\leq (\ell + 4) \text{Adv}_h^{\text{prf}}(\mathcal{A}_1) + \text{Adv}_{\bar{h}}^{\text{prf}}(\mathcal{A}_2) + \text{Adv}_{\Phi_{\text{zio}, e}, \bar{h}}^{\text{rkaprff}}(\mathcal{B}) \\ &\quad + \frac{qb(qb - 1)}{2^{n+1}} + \text{Adv}_{\text{KCTR-HMAC}[f]}^{\text{volprf}}(\mathcal{A}) , \end{aligned}$$

where $\mathcal{A}_1$ and $\mathcal{A}_2$ are adversaries against the PRF security of h and $\bar{h}$ respectively, who make at most qb queries and one query respectively, $\mathcal{B}$ is an adversary against the rka-PRF security of $\bar{h}$ that makes two queries, the running times of who are all about the same as that of $\mathcal{A}$.

We then analyze the volPRF security of $\text{KCTR-HMAC}[f]$. For any q distinct queries to $\text{KCTR-HMAC}[f]$, as the inputs to the underlying random function f are all distinct due to use of counter and the constraint that $M \neq M'$ for any two different queries M and M' , the corresponding outputs are merely q random strings. Hence, we have

$$\text{Adv}_{\text{KCTR-HMAC}[f]}^{\text{volprf}}(\mathcal{A}) = 0$$

that concludes the proof.

COLLISION RESISTANCE. As indicated in NIST SP 800-108r1-upd1 [11], it requires that derived keying material should be bound to the input of the key derivation function that is called context binding. The purpose of context binding is to provide "assurance that all parties who (correctly) derive the keying material share the same understanding of who will access it and in which session it will be used. If those parties have different understandings, then they will derive different keying material". It is therefore expected that it is hard for an adversary to obtain a pair of $(K_1, M_1) \neq (K_2, M_2)$ such that $\text{KCTR-HMAC}(K_1, M_1) = \text{KCTR-HMAC}(K_2, M_2)$, namely finding a collision against the key derivation function KCTR-HMAC. Here we say a collision happens if the two derived keying materials have the same first n bits. We suspect that although the derived keying material can allow to have arbitrary length, the collision resistance of KCTR-HMAC cannot be better than the underlying HMAC. The following theorem shows that KCTR-HMAC is collision resistant by assuming the compression function $h : \{0, 1\}^n \times \{0, 1\}^d \rightarrow \{0, 1\}^n$ is a random oracle.

Theorem 4. *Suppose that the key length of KCTR-HMAC is fixed and less than $d - 1$ bits. For any adversary $\mathcal{A}$ that makes at most p queries to the compression function h , we have*

$$\text{Adv}_{\text{KCTR-HMAC}}^{\text{coll}}(\mathcal{A}) \leq \frac{13p^2}{2^n} .$$

Proof. Let $\mathcal{A}$ be an adversary against the collision resistance security of KCTR-HMAC with oracle access to the compression function h . Suppose that the adversary

$\mathcal{A}$ finds a pair of (K_1, M_1) and (K_2, M_2) such that $\text{KCTR-HMAC}(K_1, M_1)[1 : n] = \text{KCTR-HMAC}(K_2, M_2)[1 : n]$, then we can transform this pair into another colliding pair of $(K_1, 1 \parallel M_1)$ and $(K_2, 1 \parallel M_2)$ against HMAC such that $\text{HMAC}(K_1, 1 \parallel M_1) = \text{HMAC}(K_2, 1 \parallel M_2)$. As shown by Dodis et al. [12], HMAC is indistinguishable from a random oracle when the key is of a fixed length less than $d - 1$ bits. Hence, we can use this colliding pair to attack the indistinguishability of HMAC. By [12, Theorem 4.4], we have

$$\text{Adv}_{\text{KCTR-HMAC}}^{\text{coll}}(\mathcal{A}) \leq \frac{13p^2}{2^n}.$$

COLLISION ATTACK. Note that when the key is of variable length, there is a collision attack against HMAC as shown in [12, 7]. The attack works as follows. The adversary first computes $T = \text{HMAC}(K_1, 1 \parallel M_1)$ for a pair of (K_1, M_1) . If $|K_1| < d$, then she sets $K_2 = K_1 \parallel 0$. If $|K_1| > d$, then she sets $K_2 = H(K_1)$. One can check that $\text{HMAC}(K_1, 1 \parallel M_1) = \text{HMAC}(K_2, 1 \parallel M_1)$ from the definition of HMAC. Obviously, the pair of (K_1, M_1) and (K_2, M_1) can also result in a collision on the first n -bit output of KCTR-HMAC. Hence, KCTR-HMAC is not collision resistant when the key is of variable length. This collision attack also works for KFB-HMAC and KDPL-HMAC when the key is of variable length.

PREIMAGE RESISTANCE. For a given image $T \in \{0, 1\}^n$, we say an adversary $\mathcal{A}$ finds a preimage (K, M) against KCTR-HMAC if $\text{KCTR-HMAC}(K, M)[1 : n] = T$. We also reduce the preimage resistance of KCTR-HMAC to the preimage resistance of HMAC that again is reduced to the indistinguishability of HMAC by Dodis et al. [12]. The proof is omitted as the reduction is similar to the above proof.

Theorem 5. *Suppose that the key length of KCTR-HMAC is fixed and less than $d - 1$ bits. For any adversary $\mathcal{A}$ that makes at most p queries to the compression function h , we have*

$$\text{Adv}_{\text{KCTR-HMAC}}^{\text{epre}}(\mathcal{A}) \leq \frac{13p^2}{2^n}.$$

4 Security Analysis of KDF in Feedback Mode

4.1 Security Analysis of KFB-CMAC

In this subsection, we present security analysis of key derivation function KFB-CMAC based on CMAC in feedback mode. We prove that KFB-CMAC is a secure vol-PRF with the bound $O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$. We show that KFB-CMAC is collision resistant with the bound $O(\frac{p^2}{2^n} + \frac{p^2 \ell}{2^n})$, and is preimage resistant with the bound $O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$.

SCHEME DESCRIPTION. The key derivation function KFB-CMAC based on CMAC in feedback mode takes as input a key K , two bit strings called Label and Context, an integer L that specifies the requested length in bits of the derived

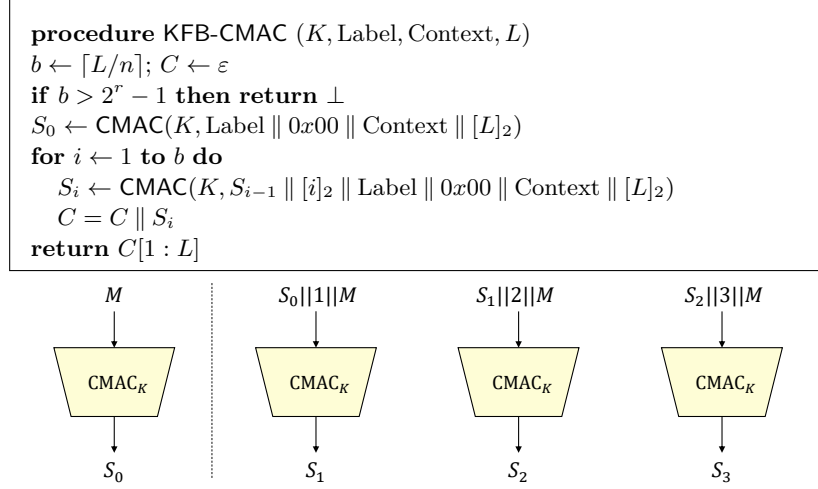


Fig. 6: The pseudocode definition of KFB-CMAC in feedback mode based on CMAC and its pictorial illustration for producing $3n$ -bit keying material $C = S_1 \parallel S_2 \parallel S_3$. Here $M = \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$.

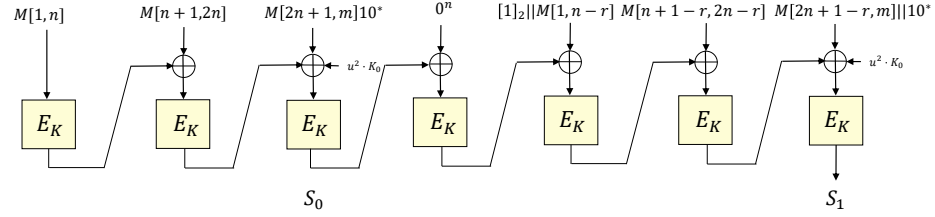


Fig. 7: The pictorial illustration for producing n -bit keying material $C = S_1$ with a message M of m bits where $2n \leq m < 3n$ and $r + m < 3n$.

keying material, and outputs a L -bit keying material C by iterating $\lceil L/n \rceil$ times CMAC where n is the block size of the underlying block cipher. In each iteration of a CMAC execution, the fixed input data is the string $\text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$. Let

$$S_0 = \text{CMAC}(K, \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2) .$$

The iteration-dependent input data is $S_i \parallel [i]_2$ where

$$S_i = \text{CMAC}(K, S_{i-1} \parallel [i]_2 \parallel \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2) ,$$

for $i \geq 1$ and $[i]_2$ is a counter that is encoded as a string of r bits. The pseudocode specification and pictorial illustration of KFB-CMAC are given in Fig. 6.

VOLPRF SECURITY. Given that the block cipher E_K is a good PRP, the key derivation function KFB-CMAC is a good volPRF as shown in the following theorem.

Theorem 6. *For any adversary $\mathcal{A}$ against the volPRF security of KFB-CMAC that runs in time at most t , makes at most q queries, with each query being of*

block length at most ℓ and being of output block length at most b , we have

$$\text{Adv}_{\text{KFB-CMAC}}^{\text{volprf}}(\mathcal{A}) \leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \frac{20q^2(b+1)^2}{2^n} + \frac{23q(b+1)(\ell+2)^2}{2^n},$$

by assuming $q(b+1) \leq 2^{n/2-1}$ and $\ell+2 \leq 2^{n/4-0.5}$, where $\mathcal{B}$ is an adversary against the PRP security of the block cipher E that runs in time at most $t' = t + q(b+1)(\ell+3)t_E$ and makes at most $q(b+1)(\ell+3)$ queries where t_E denotes the running time of one computation of E .

Proof. The procedures to replace the block cipher E_K with a random permutation $\pi \leftarrow \text{Perm}(n)$ and to replace the CMAC algorithm with a random function $f \leftarrow \text{Func}(*, n)$ are the same as the ones in the proof of Theorem 1. Following similar arguments, we have

$$\begin{aligned} \text{Adv}_{\text{KCTR-CMAC}}^{\text{volprf}}(\mathcal{A}) &\leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \frac{20q^2(b+1)^2}{2^n} + \frac{23q(b+1)(\ell+2)^2}{2^n} \\ &\quad + \text{Adv}_{\text{KCTR-CMAC}[f]}^{\text{volprf}}(\mathcal{A}), \end{aligned}$$

where $\mathcal{B}$ is an adversary against the PRP security of block cipher E that makes at most $q(b+1)(\ell+3)$ queries and runs in times at most $t' = t + q(b+1)(\ell+3)t_E$.

We then show that the key derivation function $\text{KFB-CMAC}[f]$ based on a random function f is the same as a variable output length random function. For any query M to $\text{KFB-CMAC}[f]$, the inputs of the random function f to generate the keying material C are $S_0 \parallel 1 \parallel M, S_1 \parallel 2 \parallel M, \dots, S_{b-1} \parallel b \parallel M$ that are distinct from each other as each input contains a distinct counter i for $1 \leq i \leq b$. Therefore, the corresponding outputs $S_1, S_2, \dots, S_b$ are independently random strings. Hence, the final L -bit keying material C is a random string as it is a L -bit truncation of the random string $S_1 \parallel S_2 \parallel \dots \parallel S_b$. For any two distinct queries M and M' to $\text{KFB-CMAC}[f]$, the inputs to produce keying materials C and C' are distinct from each other as $M \neq M'$. Hence, the two keying materials C and C' are independently random strings. From the similar argument, for any q distinct queries to $\text{KFB-CMAC}[f]$, the outputs of $\text{KFB-CMAC}[f]$ are q random and independent strings, as the inputs of the underlying random function f to generate these strings are distinct with the help of counter i and non-repeating M in each query. Therefore,

$$\text{Adv}_{\text{KFB-CMAC}[f]}^{\text{volprf}}(\mathcal{A}) = 0,$$

which completes the proof.

COLLISION RESISTANCE. Here we say a collision happens if two derived keying materials have the same first n bits, namely the adversary finds a pair of (K_1, M_1) and (K_2, M_2) such that $\text{KFB-CMAC}(K_1, M_1)[1 : n] = \text{KFB-CMAC}(K_2, M_2)[1 : n]$. The following theorem shows that KFB-CMAC is collision resistant.

Theorem 7. *For any adversary $\mathcal{A}$ that makes at most p ideal-cipher queries to E and E^{-1} , we have*

$$\text{Adv}_{\text{KFB-CMAC}}^{\text{coll}}(\mathcal{A}) \leq \frac{2p^2\ell + p(p+3)}{2^n} ,$$

where ℓ is the maximum block length of a query to the key derivation function.

Proof. Let $\mathcal{A}$ be an adversary that aims at finding a collision pair for the key derivation function KFB-CMAC, namely a pair of $(K_1, M_1) \neq (K_2, M_2)$ such that $\text{KFB-CMAC}(K_1, M_1)[1:n] = \text{KFB-CMAC}(K_2, M_2)[1:n]$. Assume that $\mathcal{A}$ asks at most p queries to E and E^{-1} in total. Note that to determine the output of key derivation function KFB-CMAC, it requires one of iterated CMAC chains is fully determined so that the rest of CMAC chains can be determined subsequently. In the following, we call the query to the key derivation function KFB-CMAC as construction query, and the query to E or E^{-1} as ideal cipher query.

We now consider the probability that a collision happens at the i -th construction query (K_i, M_i) to KFB-CMAC. It implies that there exists some $1 \leq j < i$ such that $\text{KFB-CMAC}(K_i, M_i)[1:n] = \text{KFB-CMAC}(K_j, M_j)[1:n]$. The query (K_i, M_i) to KFB-CMAC is built from ideal cipher queries to E and E^{-1} . Denote by m the bit length of message M_i . Let $\ell = \lceil m/n \rceil$. We consider the case of $m + r < n\ell$ where r is the bit length of the binary encoding of counter i . The other case of $m + r \geq n\ell$ can be analyzed similarly. Then the output of $\text{KFB-CMAC}(K_i, M_i)[1:n]$ is defined as $S_1^i = Y_{2\ell+1}^i$ (see Fig. 7 for the pictorial illustration for the case of a three-block message M), where the internal block cipher calls during the computation of this query are:

$$Y_j^i = E_{K_i}(X_j^i) \text{ for } 1 \leq j \leq 2\ell + 1 ,$$

and

$$\begin{aligned} Y_0^i &= 0^n \\ X_j^i &= Y_{j-1}^i \oplus M_i[n(j-1) + 1 : nj] \text{ for } 1 \leq j \leq \ell - 1 \\ X_\ell^i &= Y_{\ell-1}^i \oplus M_i[n(\ell-1) + 1 : m] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) \\ X_{\ell+1}^i &= Y_\ell^i \oplus 0^n \\ X_{\ell+2}^i &= Y_{\ell+1}^i \oplus [1]_2 \parallel M_i[1 : n - r] \\ X_{\ell+j+1}^i &= Y_{\ell+j-1}^i \oplus M_i[n(j-1) - r + 1 : nj - r] \text{ for } 2 \leq j \leq \ell \\ X_{2\ell+1}^i &= Y_{2\ell}^i \oplus M_i[n(\ell-1) + 1 - r : m] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) . \end{aligned}$$

As mentioned above, in order to determine the output of this construction query, it requires one of two iterated CMAC chains among the computation of S_1^i is fully determined. Without loss of generality, we assume that the first CMAC chain is fully determined firstly. We then proceed to analyze the collision probability by considering the type of ideal cipher queries to build this CMAC chain.

If the last block cipher call $(K_i, X_{\ell+1}^i, Y_{\ell+1}^i)$ in the first CMAC chain is a forward query, then we can rely on the randomness of $Y_{\ell+1}^i$. However, as the

adversary may control the first CMAC chain and choose ideal cipher queries such that $S_0^i = S_0^j$ for some $j < i$ with $K_i = K_j$. In this case, if $[1]_2 \parallel M_i[1, n-r] = [1]_2 \parallel M_j[1, n-r]$, then subsequently $X_{\ell+2}^i = X_{\ell+2}^j$ holds. Namely, there may exist a common prefix between this message and some previous message in the second CMAC chain. To handle this issue, let

$$c = \max\{d \mid \exists j < i: K_i = K_j \wedge S_0^i = S_0^j \wedge M_i[1 : nd-r] = M_j[1 : nd-r]\} .$$

Note that the value d should be in $[0, \ell)$ and cannot be greater than or equal to ℓ , otherwise the input (K_j, M_j) will be the same as the input (K_i, M_i) . We proceed to consider the randomness of $Y_{\ell+1+c}^i$. The input to the next block cipher call is $X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus M_i[nc-r+1 : n(c+1)-r]$ if $c > 0$ and $X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus [1]_2 \parallel M_i[1 : n-r]$ if $c = 0$. We say a collision event $\text{fcoll}_{i,\ell+c+2}$ happens if $X_{\ell+c+2}^i$ hits previous inputs of the block cipher E_{K_i} . Then we have

$$\Pr[\text{fcoll}_{i,c}] \leq \frac{p_{i,\ell+c+1}}{2^n - p_{i,\ell+c+1}} ,$$

as $Y_{\ell+c+1}^i$ is selected uniformly at random from a set of size at least $2^n - p_{i,\ell+c+1}$ where $p_{i,\ell+c+1}$ denotes the total number of ideal cipher queries at the $(\ell+c+1)$ -th block cipher call in this construction query. More generally, let $\text{fcoll}_{i,\ell+2+j}$ be the event that $X_{\ell+2+j}^i$ hits previous inputs of the block cipher E_{K_i} for $c \leq j \leq \ell-1$. Let $\text{Fcoll}_i = \bigvee_{j=c}^{\ell-1} \text{fcoll}_{i,\ell+2+j}$. Obviously, if the event Fcoll_i does not happen, then S_1^i is distributed uniformly at random in a set of size at least $2^n - p_{i,2\ell+1}$. Let $\widetilde{\text{Fcoll}}_i$ be the event that S_1^i does not collide with previous S_1^j for $1 \leq j \leq i-1$. Hence, the probability of the event $\widetilde{\text{Fcoll}}_i$ can be bounded by

$$\begin{aligned} \Pr[\widetilde{\text{Fcoll}}_i] &\leq \Pr[\text{Fcoll}_i \mid \overline{\text{Fcoll}}_i] + \Pr[\text{Fcoll}_i] \\ &\leq \frac{i-1}{2^n - p_{i,2\ell+1}} + \Pr[\bigvee_{j=c}^{\ell-1} \text{fcoll}_{i,\ell+2+j}] \\ &\leq \frac{i-1}{2^n - p_{i,2\ell+1}} + \Pr[\text{fcoll}_{i,\ell+2+c}] \\ &\quad + \sum_{j=c+1}^{\ell-1} \Pr[\text{fcoll}_{i,\ell+2+j} \mid \overline{\text{fcoll}}_{i,\ell+2+c} \wedge \cdots \wedge \overline{\text{fcoll}}_{i,\ell+1+j}] \\ &\leq \frac{i-1}{2^n - p_{i,2\ell+1}} + \sum_{j=c}^{\ell-1} \frac{p_{i,\ell+1+j}}{2^n - p_{i,\ell+1+j}} \\ &\leq \frac{2(i-1)}{2^n} + \frac{2p\ell}{2^n} , \end{aligned}$$

by assuming $p_{i,j} \leq p \leq 2^{n-1}$.

If the last block cipher call $(K_i, X_{\ell+1}^i, Y_{\ell+1}^i)$ in the first CMAC chain is a backward query, then we can rely on the randomness of its inverse output $X_{\ell+1}^i$. We consider different cases depending on whether the preceding block cipher call is a forward query or a backward query. If the preceding block cipher call

$(K_i, X_\ell^i, Y_\ell^i)$ is a forward query, then it requires that $X_{\ell+1}^i = Y_\ell^i \oplus 0^n$, and we denote this event by E_0 . Then event E_0 happens with probability $1/(2^n - p_{i,\ell})$ as Y_ℓ^i is distributed uniformly at random in a set of size at least $2^n - p_{i,\ell}$. If the preceding block cipher call $(K_i, X_\ell^i, Y_\ell^i)$ is a backward query, then the adversary can simply set $Y_\ell^i = X_{\ell+1}^i$ and does the backward query to obtain X_ℓ^i . Then we continue to consider previous preceding queries until there is a forward query (K_i, X_j^i, Y_j^i) with $1 < j < \ell$. In this case, as (K_i, X_j^i, Y_j^i) is a forward query, Y_j^i is selected uniformly at random from a set of size at least $2^n - p_{i,j}$. In addition, its succeeding block cipher call $(K_i, X_{j+1}^i, Y_{j+1}^i)$ is a backward query, which means that X_{j+1}^i is distributed uniformly at random from a set of size at least $2^n - p_{i,j+1}$. Hence, the message block $M_i[nj+1 : n(j+1)] = X_{j+1}^i \oplus Y_j^i$ is uniformly distributed in a set of size at least $2^n - \max\{p_{i,j}, p_{i,j+1}\}$. In the case that all of preceding queries are backward queries, then we will reach the first block $M_i[1 : n]$ that is the output of $E_{K_i}^{-1}(X_1^i)$ which is distributed uniformly at random in a set of size at least $2^n - p_{i,1}$. Without loss of generality, assume that all of message blocks besides this random message block has been determined during the computation of the first CMAC chain. Denote by $M_i[nc+1 : n(c+1)]$ this random message block where $0 \leq c < \ell - 1$. We then analyze the influence of this message block on the second CMAC chain. As this random message block may spread into two block cipher calls with inputs

$$X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus M_i[nc-r+1 : n(c+1)-r]$$

and

$$X_{\ell+c+3}^i = Y_{\ell+c+2}^i \oplus M_i[n(c+1)-r+1 : n(c+2)-r]$$

if $c > 0$, and with inputs

$$X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus [1]_2 \parallel M_i[1 : n-r]$$

and

$$X_{\ell+c+3}^i = Y_{\ell+c+2}^i \oplus M_i[n-r+1 : 2n-r]$$

if $c = 0$, we consider a joint event for these two block cipher calls. We say the event E_1 happens if $X_{\ell+c+2}^i$ appears in previous inputs of the block cipher E_{K_i} , and the event E_2 happens if $X_{\ell+c+3}^i$ appears in previous inputs of the block cipher E_{K_i} . Then we have

$$\begin{aligned} \Pr[E_2] &= \Pr[E_2 \wedge E_1] + \Pr[E_2 \wedge \bar{E}_1] \\ &= \Pr[E_2 \mid E_1] \cdot \Pr[E_1] + \Pr[E_2 \mid \bar{E}_1] \cdot \Pr[\bar{E}_1] \\ &\leq \Pr[E_2 \mid E_1] \cdot \Pr[E_1] + \Pr[E_2 \mid \bar{E}_1] \end{aligned} \quad (5)$$

as $\Pr[\bar{E}_1] \leq 1$. Following similar arguments as in the proof of Theorem 2, we can obtain

$$\Pr[E_2] \leq \frac{p_{i,\ell+c+2} + 1}{2^n - p_{i,c+1}} + \frac{p_{i,\ell+c+2}}{2^n - p_{i,\ell+c+2}}.$$

We then continue to analyze subsequent block cipher calls. Denote by $\text{bcoll}_{i,\ell+c+j}$ the collision event that $X_{\ell+c+j}^i = Y_{\ell+c+j-1}^i \oplus M_i[n(c+j-1)-r+1 : n(c+j)-r]$

hits previous inputs of the block cipher E_{K_i} for $3 \leq j \leq \ell + 1 - c$. Let $\text{Bcoll}_i = E_0 \vee E_2 \vee (\bigvee_{j=3}^{\ell+1-c} \text{bcoll}_{i,\ell+c+j})$. If Bcoll_i does not happen, then obviously S_1^i is distributed uniformly at random in a set of size at least $2^n - p_{i,2\ell+1}$. Let $\widetilde{\text{Bcoll}}_i$ be the event that S_1^i collides with previous S_1^j for $1 \leq j \leq i-1$. Thus, the collision probability at the i -th construction query can be bounded by

$$\begin{aligned}
\Pr[\widetilde{\text{Bcoll}}_i] &\leq \Pr[\widetilde{\text{Bcoll}}_i \mid \overline{\text{Bcoll}}_i] + \Pr[\text{Bcoll}_i] \\
&\leq \frac{i-1}{2^n - p_{i,2\ell+1}} + \Pr[E_0 \vee E_2 \vee (\bigvee_{j=3}^{\ell+1-c} \text{bcoll}_{i,\ell+c+j})] \\
&\leq \frac{i-1}{2^n - p_{i,2\ell+1}} + \Pr[E_0] + \Pr[E_2] + \Pr[\text{bcoll}_{i,\ell+c+3}] \\
&\quad + \sum_{j=4}^{\ell+1-c} \Pr[\text{bcoll}_{i,\ell+c+j} \mid \overline{\text{bcoll}}_{i,\ell+c+3} \wedge \cdots \wedge \overline{\text{bcoll}}_{i,\ell+c+j-1} \wedge \overline{E_2} \wedge \overline{E_0}] \\
&\leq \frac{i-1}{2^n - p_{i,2\ell+1}} + \frac{1}{2^n - p_{i,\ell}} + \frac{p_{i,\ell+c+2} + 1}{2^n - p_{i,c+1}} + \sum_{j=3}^{\ell+1-c} \frac{p_{i,\ell+c+j-1}}{2^n - p_{i,\ell+c+j-1}} \\
&\leq \frac{2(i+1)}{2^n} + \frac{2p\ell}{2^n},
\end{aligned}$$

by assuming $p_{i,j} \leq p \leq 2^{n-1}$.

Let $\text{Coll}_i = \max\{\widetilde{\text{Fcoll}}_i, \widetilde{\text{Bcoll}}_i\}$ for $1 \leq i \leq q$. Let $\text{Coll} = \bigvee_{i=1}^q \text{Coll}_i$. Then we finally have

$$\Pr[\text{Coll}] \leq \sum_{i=1}^q \Pr[\text{Coll}_i] \leq \sum_{i=1}^q \left(\frac{2(i+1)}{2^n} + \frac{2p\ell}{2^n} \right) \leq \frac{2p^2\ell + p(p+3)}{2^n}$$

as $q \leq p$ and finish the proof.

PREIMAGE RESISTANCE. Given a n -bit value T , we say that the adversary $\mathcal{A}$ finds a preimage against KFB-CMAC if she outputs a pair of (K, M) such that $\text{KFB-CMAC}(K, M)[1:n] = T$. The following theorem shows that KFB-CMAC is preimage resistant.

Theorem 8. *For any adversary $\mathcal{A}$ that makes at most p ideal-cipher queries to E and E^{-1} , we have*

$$\text{Adv}_{\text{KFB-CMAC}}^{\text{epre}}(\mathcal{A}) \leq \frac{4p}{2^n} + \frac{2p^2\ell}{2^n},$$

where ℓ is the maximum block length of a query to the key derivation function.

Proof. Let $\mathcal{A}$ be an adversary against the preimage security of the key derivation function KFB-CMAC. For any fixed image $C \in \{0, 1\}^n$, the adversary $\mathcal{A}$ aims at finding a pair of (K, M) satisfying $\text{KFB-CMAC}(K, M)[1:n] = T$. Assume that the adversary makes at most p queries to E and E^{-1} . We call the query to key

derivation function KFB-CMAC as construction query, and the query to E or E^{-1} as ideal cipher query.

Fix an image $T \in \{0, 1\}^n$. We then analyze the event P_i that the adversary finds the preimage for T at the i -th construction query (K_i, M_i) , namely the event that $\text{KFB-CMAC}(K_i, M_i)[1 : n] = T$. The construction query (K_i, M_i) to KFB-CMAC consists of ideal cipher queries to E and E^{-1} . Following the same notations as in the proof of Theorem 7, let m be the bit length of message M_i . We consider the case of $m + r < n\ell$ where r is the bit length of the encoding of the counter i . The other case of $m + r \geq n\ell$ can be analyzed similarly. Then the output of $\text{KFB-CMAC}(K_i, M_i)$ is defined as $S_1^i = Y_{2\ell+1}^i$, where internal block cipher calls among the computation of this query are:

$$Y_j^i = E_{K_i}(X_j^i) \text{ for } 1 \leq j \leq 2\ell + 1 ,$$

and

$$\begin{aligned} Y_0^i &= 0^n \\ X_j^i &= Y_{j-1}^i \oplus M_i[n(j-1) + 1 : nj] \text{ for } 1 \leq j \leq \ell - 1 \\ X_\ell^i &= Y_{\ell-1}^i \oplus M_i[n(\ell-1) + 1 : m] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) \\ X_{\ell+1}^i &= Y_\ell^i \oplus 0^n \\ X_{\ell+2}^i &= Y_{\ell+1}^i \oplus [1]_2 \parallel M_i[1 : n-r] \\ X_{\ell+j+1}^i &= Y_{\ell+j}^i \oplus M_i[n(j-1) - r + 1 : nj - r] \text{ for } 2 \leq j \leq \ell \\ X_{2\ell+1}^i &= Y_{2\ell}^i \oplus M_i[n(\ell-1) + 1 - r : m] \parallel 10^* \oplus u^2 \cdot E_{K_i}(0^n) . \end{aligned}$$

To determine the output of this construction query, it requires that one of two iterated CMAC chains among the computation of S_1^i is fully determined. Without loss of generality, we assume that the first CMAC chain is fully determined at first. We then proceed to analyze the probability that at the i -th construction query, the output equals to the given image T by considering the type of ideal cipher queries. The following preimage analysis resorts to some results in the proof of Theorem 7.

We first consider the case when the last block cipher call $(K_i, X_{\ell+1}^i, Y_{\ell+1}^i)$ in the first CMAC chain is a forward query. Let

$$c = \max\{d \mid \exists j < i: K_i = K_j \wedge S_0^i = S_0^j \wedge M_i[1 : nd - r] = M_j[1 : nd - r]\} .$$

Namely, c is the length of the longest common prefix between this message and previous messages in the second CMAC chain. We consider the randomness of $Y_{\ell+1+c}^i$. The input to the next block cipher call is $X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus M_i[nc - r + 1 : n(c+1) - r]$ if $c > 0$ and $X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus [1]_2 \parallel M_i[1 : n-r]$ if $c = 0$. Similar to the proof of Theorem 7, let $\text{fcoll}_{i, \ell+c+2}$ be the event that $X_{\ell+c+2}^i$ hits previous inputs of the block cipher E_{K_i} . Then we have

$$\Pr[\text{fcoll}_{i, \ell+c+2}] \leq \frac{p_{i, \ell+c+1}}{2^n - p_{i, \ell+c+1}} ,$$

since $Y_{\ell+c+1}^i$ is selected uniformly at random from a set of size at least $2^n - p_{i,\ell+c+1}$ where $p_{i,\ell+c+1}$ denotes the total number of ideal cipher queries at the $(\ell + c + 1)$ -th block cipher call in this construction query. More generally, let $\text{fcoll}_{i,\ell+2+j}$ be the event that $X_{\ell+2+j}^i$ hits previous inputs of the block cipher E_{K_i} for $c \leq j \leq \ell - 1$, and $\text{Fcoll}_i = \bigvee_{j=c}^{\ell-1} \text{fcoll}_{i,\ell+2+j}$. If the event Fcoll_i does not happen, then S_1^i is distributed uniformly at random in a set of size at least $2^n - p_{i,2\ell+1}$. Hence, the probability of the event P_i can be bounded by

$$\begin{aligned} \Pr[P_i] &\leq \Pr[P_i \mid \overline{\text{Fcoll}_i}] + \Pr[\text{Fcoll}_i] \\ &\leq \frac{1}{2^n - p_{i,2\ell+1}} + \sum_{j=c}^{\ell-1} \frac{p_{i,\ell+1+j}}{2^n - p_{i,\ell+1+j}} \\ &\leq \frac{2}{2^n} + \frac{2p\ell}{2^n}, \end{aligned}$$

by assuming $p_{i,j} \leq p \leq 2^{n-1}$.

Next, we consider the case when the last block cipher call $(K_i, X_{\ell+1}^i, Y_{\ell+1}^i)$ in the first CMAC chain is a backward query. We proceed the analysis depending on whether the preceding block cipher call is a forward query or a backward query. If the preceding block cipher call $(K_i, X_\ell^i, Y_\ell^i)$ is a forward query, then it requires that $X_{\ell+1}^i = Y_\ell^i \oplus 0^n$ that is denoted as the event E_0 . Event E_0 happens with probability at most $1/(2^n - p_{i,\ell})$ as Y_ℓ^i is distributed uniformly at random in a set of size at least $2^n - p_{i,\ell}$. If the preceding block cipher call $(K_i, X_\ell^i, Y_\ell^i)$ is a backward query, then the adversary can set $Y_\ell^i = X_{\ell+1}^i$ and asks the backward query to obtain X_ℓ^i . Then we continue to consider previous preceding queries until (K_i, X_j^i, Y_j^i) is a forward query for $1 \leq j \leq \ell$. In this case, Y_j^i is distributed uniformly at random in a set of size at least $2^n - p_{i,j}$ as (K_i, X_j^i, Y_j^i) is a forward query, while X_{j+1}^i is distributed uniformly at random in a set of size at least $2^n - p_{i,j+1}$ as $(K_i, X_{j+1}^i, Y_{j+1}^i)$ is a backward query. Hence, the message block $M_i[nj + 1 : n(j + 1)] = X_{j+1}^i \oplus Y_j^i$ is uniformly distributed at random in a set of size at least $2^n - \max\{p_{i,j+1}, p_{i,j}\}$. In the case that all of preceding queries are backward queries, then the first message block $M_i[1 : n]$ is distributed uniformly at random in a set of size at least $2^n - p_{i,1}$ as it is the output of $E_{K_i}^{-1}(X_1^i)$. Denote by $M_i[nc + 1 : n(c + 1)]$ this random message block where $0 \leq c < \ell - 1$. Without loss of generality, assume that all of message blocks including this random message block has been determined during the computation of the first CMAC chain. We then analyze the influence of this random message block on the computation of second CMAC chain. If $c = 0$, then this random message block will spread into two block cipher calls with inputs

$$X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus [1]_2 \parallel M_i[1 : n - r]$$

and

$$X_{\ell+c+3}^i = Y_{\ell+c+2}^i \oplus M_i[n - r + 1 : 2n - r].$$

If $c > 0$, then it will spread into two block cipher calls with inputs

$$X_{\ell+c+2}^i = Y_{\ell+c+1}^i \oplus M_i[nc - r + 1 : n(c + 1) - r]$$

and

$$X_{\ell+c+3}^i = Y_{\ell+c+2}^i \oplus M_i[n(c+1) - r + 1 : n(c+2) - r] .$$

Let E_2 be the event that $X_{\ell+c+3}^i$ hits the previous inputs of the block cipher E_{K_i} . Following the analysis in the proof of Theorem 7, we have

$$\Pr[E_2] \leq \frac{p_{i,\ell+c+2} + 1}{2^n - p_{i,c+1}} + \frac{p_{i,\ell+c+2}}{2^n - p_{i,\ell+c+2}} .$$

We then analyze subsequent block cipher calls in the second CMAC chain. Let $\text{bcoll}_{i,\ell+c+j}$ be the event that $X_{\ell+c+j}^i = Y_{\ell+c+j-1}^i \oplus M_i[n(j+c-1) - r + 1 : n(j+c) - r]$ hits previous inputs of the block cipher E_{K_i} for $3 \leq j \leq \ell+1-c$. Let $\text{Bcoll}_i = E_0 \vee E_2 \vee (\bigvee_{j=3}^{\ell+1-c} \text{bcoll}_{i,\ell+c+j})$. If Bcoll_i does not happen, then S_1^i is distributed uniformly at random in a set of size at least $2^n - p_{i,2\ell+1}$. Hence, the probability of the event P_i can be bounded by

$$\begin{aligned} \Pr[P_i] &\leq \Pr[P_i \mid \overline{\text{Bcoll}_i}] + \Pr[\text{Bcoll}_i] \\ &\leq \frac{1}{2^n - p_{i,2\ell+1}} + \Pr[E_0 \vee E_2 \vee (\bigvee_{j=3}^{\ell+1-c} \text{bcoll}_{i,\ell+c+j})] \\ &\leq \frac{1}{2^n - p_{i,2\ell+1}} + \Pr[E_0] + \Pr[E_2] + \Pr[\text{bcoll}_{i,\ell+c+3}] \\ &\quad + \sum_{j=4}^{\ell+1-c} \Pr[\text{bcoll}_{i,\ell+c+j} \mid \overline{\text{bcoll}_{i,\ell+c+3}} \wedge \cdots \wedge \overline{\text{bcoll}_{i,\ell+c+j-1}} \wedge \overline{E_2} \wedge \overline{E_0}] \\ &\leq \frac{1}{2^n - p_{i,2\ell+1}} + \frac{1}{2^n - p_{i,\ell}} + \frac{p_{i,\ell+c+2} + 1}{2^n - p_{i,c+1}} + \sum_{j=3}^{\ell+1-c} \frac{p_{i,\ell+c+j-1}}{2^n - p_{i,\ell+c+j-1}} \\ &\leq \frac{4}{2^n} + \frac{2p\ell}{2^n} , \end{aligned}$$

by assuming $p_{i,j} \leq p \leq 2^{n-1}$.

Let $\Pr[P_i] = \max\{\frac{2}{2^n} + \frac{2p\ell}{2^n}, \frac{4}{2^n} + \frac{2p\ell}{2^n}\} = \frac{4}{2^n} + \frac{2p\ell}{2^n}$. Summing over at most $q \leq p$ construction queries, we have

$$\begin{aligned} \text{Adv}_{\text{KFB-CMAC}}^{\text{pre}}(\mathcal{A}) &\leq \sum_{i=1}^q \Pr[P_i] \\ &\leq \sum_{i=1}^q \frac{4}{2^n} + \frac{2p\ell}{2^n} \\ &\leq \frac{4p}{2^n} + \frac{2p^2\ell}{2^n} , \end{aligned}$$

by assuming $q \leq p \leq 2^{n-1}$ which completes the proof.

4.2 Security Analysis of KFB-HMAC

In this subsection, we present security proofs for key derivation function KFB-HMAC based on HMAC in feedback mode. We prove that KFB-HMAC is a secure volPRF

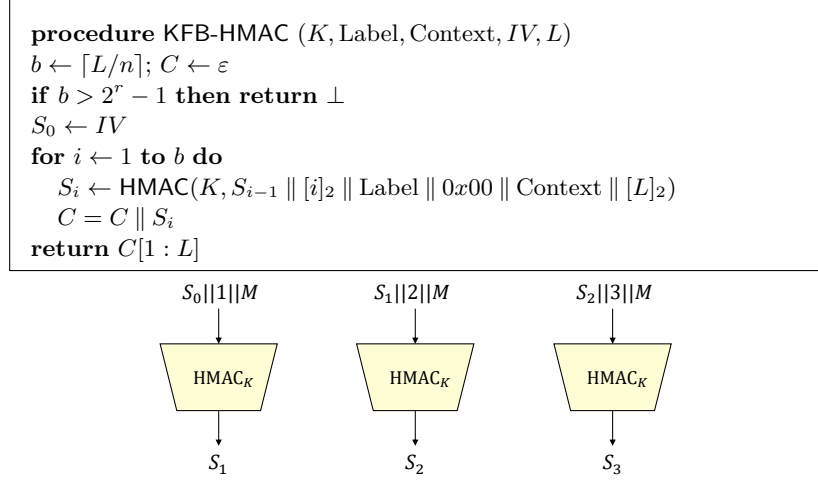


Fig. 8: The pseudocode definition of KFB-HMAC in feedback mode based on HMAC and its pictorial illustration for producing $3n$ -bit keying material $C = S_1 \parallel S_2 \parallel S_3$. Here $M = \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$. The counter i is optional in KFB-HMAC.

with the bound $O(\frac{q^2 b^2}{2^n} + \frac{qb^2}{2^n})$. We show that KFB-HMAC is collision resistant and preimage resistant with the bound $O(\frac{p^2}{2^n})$ when the key is of fixed length and less than $d - 1$ bits.

SCHEME DESCRIPTION. By setting S_0 in the specification of KFB-CMAC to a fixed initial value IV and replacing CMAC with HMAC, we can obtain KFB-HMAC. In addition, the counter i used in each iteration of HMAC becomes optional. The pseudocode description and pictorial illustration of KFB-HMAC are given in Fig. 8.

VOLPRF SECURITY. Assuming that h is a dual-PRF and $\bar{h}$ is a rka-PRF, the following theorem shows that KFB-HMAC is a volPRF. Here the proof is done when the optional counter i is not included in the input of each iteration of HMAC. The proof applies to the case when the counter i is included as the counter can only enhance the security of the scheme and make the analysis easier.

Theorem 9. *For any adversary $\mathcal{A}$ against the volPRF security of KCTR-HMAC that runs in time at most t , makes at most q queries, with each query being of block length at most ℓ and being of output block length at most b , we have*

$$\text{Adv}_{\text{KFB-HMAC}}^{\text{volprf}}(\mathcal{A}) \leq (\ell+4) \text{Adv}_h^{\text{prf}}(\mathcal{A}_1) + \text{Adv}_{\bar{h}}^{\text{prf}}(\mathcal{A}_2) + \text{Adv}_{\Phi_{\text{zio},e},\bar{h}}^{\text{rkapr}}(\mathcal{B}) + \frac{qb(qb-1)}{2^{n+1}} + \frac{qb^2}{2^{n+1}}.$$

Adversaries $\mathcal{A}_1$ and $\mathcal{A}_2$ are against the PRF security of h and $\bar{h}$ respectively, where $\mathcal{A}_1$ makes at most qb queries and $\mathcal{A}_2$ makes one query. Adversary $\mathcal{B}$ makes two queries. The running times of adversaries $\mathcal{A}_1, \mathcal{A}_2$ and $\mathcal{B}$ are about the same as that of $\mathcal{A}$.

Proof. Similar to the proof of Theorem 3, we first replace HMAC of KFB-HMAC with a random function $f \leftarrow \text{Func}(\{0,1\}^* \times \{0,1\}^*, \{0,1\}^n)$ and let the resulting key derivation function be KFB-HMAC[f]. By [1, Theorem 8] that shows HMAC is a good PRF, we have

$$\begin{aligned} \text{Adv}_{\text{KFB-HMAC}}^{\text{volprf}}(\mathcal{A}) &\leq (\ell + 4) \text{Adv}_h^{\text{prf}}(\mathcal{A}_1) + \text{Adv}_{\bar{h}}^{\text{prf}}(\mathcal{A}_2) + \text{Adv}_{\Phi_{\text{zio},e},\bar{h}}^{\text{rkapr}}(\mathcal{B}) \\ &\quad + \frac{qb(qb-1)}{2^{n+1}} + \text{Adv}_{\text{KFB-HMAC}[f]}^{\text{volprf}}(\mathcal{A}) , \end{aligned}$$

where $\mathcal{A}_1$ is an adversary against the PRF security of h that makes at most qb queries, $\mathcal{A}_2$ is an adversary against the PRF security of $\bar{h}$ that makes one query, and $\mathcal{B}$ is an adversary against the rka-PRF security of $\bar{h}$ that makes two queries, the time complexity of who are all about the same as that of $\mathcal{A}$.

We proceed to analyze the volPRF security of KFB-HMAC[f]. Recall that we analyze the case where the counter i is not included in the input. At the i -th query M_i to KFB-HMAC[f], the inputs of random function f to generate strings $S_1^i, \dots, S_b^i$ are $S_0^i \parallel M_i, \dots, S_{b-1}^i \parallel M_i$. If S_j^i does not collide with previous $S_0^i, \dots, S_{j-1}^i$, then the input of random function f is fresh, therewith the corresponding output S_{j+1}^i at this block is a random string. Let $\text{bad}_{i,j}$ be the event that at the i -th query, S_j^i collides with previous $S_0^i, \dots, S_{j-1}^i$. Note that the inputs of random function f at the i -th query will not collide with the inputs of random function f at the j -th query for $i \neq j$ as they contain two different strings that are M_i and M_j . Let $\text{bad} = \bigvee_{i=1}^q (\bigvee_{j=1}^b \text{bad}_{i,j})$. If the event bad does not happen, the outputs of KFB-HMAC[f] are merely random strings. Hence, KFB-HMAC behaves exactly the same as a variable length output random function if bad does not happen. From the fundamental lemma of game-playing technique [5], we have

$$\text{Adv}_{\text{KFB-HMAC}[f]}^{\text{volprf}}(\mathcal{A}) \leq \Pr[\text{bad}] ,$$

where

$$\begin{aligned} \Pr[\text{bad}] &\leq \sum_{i=1}^q \sum_{j=1}^b \text{bad}_{i,j} \\ &\leq \sum_{i=1}^q \sum_{j=1}^b \frac{j-1}{2^n} \\ &\leq \frac{qb^2}{2^{n+1}} . \end{aligned}$$

Combining above equations, we prove the result of this theorem.

COLLISION RESISTANCE. We say a collision happens against KFB-HMAC if the adversary finds a pair of (K_1, M_1) and (K_2, M_2) such that the first n bits of KFB-HMAC(K_1, M_1) and KFB-HMAC(K_2, M_2) collides. The following theorem shows that KFB-HMAC is collision resistant when the key is of fixed length and

less than $d - 1$ bits. The proof is omitted as it is similar to the one of Theorem 4. Note that similar to KCTR-HMAC, we can mount collision attack against KFB-HMAC when the key is of arbitrary length.

Theorem 10. *Suppose that the key length of KFB-HMAC is fixed and less than $d - 1$ bits. For any adversary $\mathcal{A}$ that makes at most p queries to the compression function h , we have*

$$\text{Adv}_{\text{KFB-HMAC}}^{\text{coll}}(\mathcal{A}) \leq \frac{13p^2}{2^n} .$$

PREIMAGE RESISTANCE. For any $T \in \{0, 1\}^n$, we say the adversary finds a preimage against KFB-HMAC if she outputs a pair of (K, M) such that the first n -bit of KFB-HMAC equals to T . The following theorem shows that KFB-HMAC is preimage resistant. The proof is similar to that of Theorem 5, and thus is omitted.

Theorem 11. *Suppose that the key length of KFB-HMAC is fixed and less than $d - 1$ bits. For any adversary $\mathcal{A}$ that makes at most p queries to the compression function h , we have*

$$\text{Adv}_{\text{KFB-HMAC}}^{\text{epre}}(\mathcal{A}) \leq \frac{13p^2}{2^n} .$$

5 Security Analysis of KDF in Double-Pipeline Mode

5.1 Security Analysis of KDPL-CMAC

In this subsection, we show that the key derivation function KDPL-CMAC based on CMAC in double-pipeline mode is a secure volPRF with the bound $O(\frac{q^2 b^2}{2^n} + \frac{q b \ell^2}{2^n})$. We also show that KDPL-CMAC is collision resistant and preimage resistant with bounds $O(\frac{p^2}{2^n} + \frac{p^2 \ell}{2^n})$ and $O(\frac{p}{2^n} + \frac{p^2 \ell}{2^n})$ respectively.

SCHEME DESCRIPTION. The key derivation function KDPL-CMAC using CMAC as the PRF in double-pipeline mode takes as input a key K , two strings called Label and Context, an integer L specifying the output length of the derived keying material, and outputs a L -bit string as the derived keying material. In the first pipeline, the CMAC iterations work in a feedback mode with a key K and an initial value $A_0 = \text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$ to generate strings A_i . In the second pipeline, each CMAC iteration generates a n -bit string S_i with the key K from the fixed input data $\text{Label} \parallel 0x00 \parallel \text{Context} \parallel [L]_2$, the iteration-dependent input data A_i , and a counter $[i]_2$ that is represented as a r -bit string. The pseudocode description and pictorial illustration of KDPL-CMAC can be found in Fig. 9.

VOLPRF SECURITY. The following theorem shows that KDPL-CMAC is a good volPRF under the assumption that E_K is a good PRP.

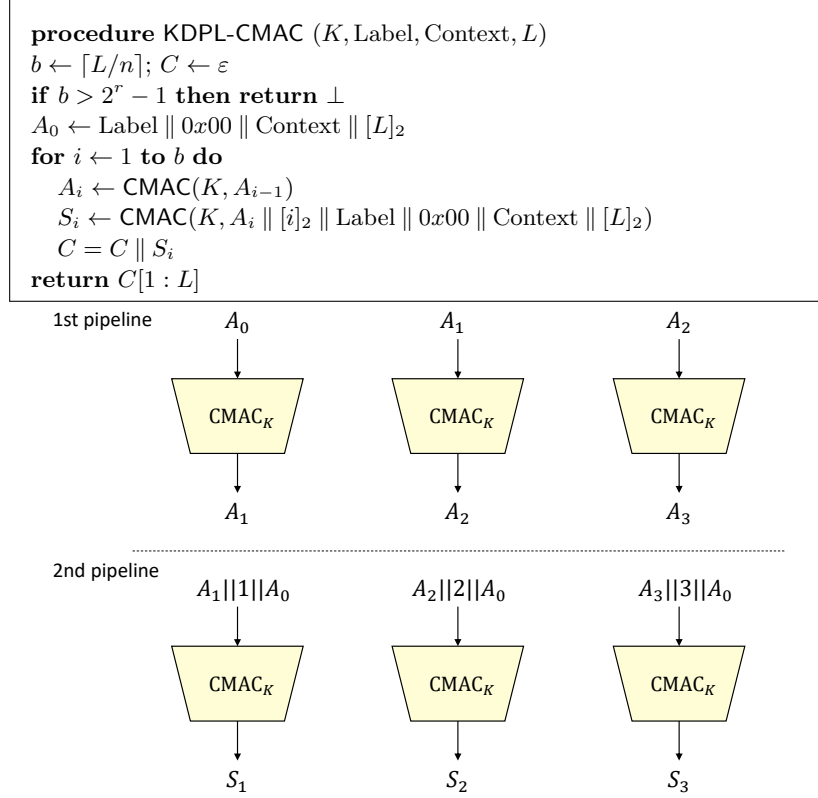


Fig. 9: The pseudocode definition of KDPL-CMAC in double-pipeline mode based on CMAC and its pictorial illustration for producing $3n$ -bit keying material $C = S_1 \parallel S_2 \parallel S_3$.

Theorem 12. *For any adversary $\mathcal{A}$ against the volPRF security of KDPL-CMAC that runs in time at most t , makes at most q queries, with each query being of block length at most ℓ and being of output block length at most b , we have*

$$\text{Adv}_{\text{KFB-CMAC}}^{\text{volprf}}(\mathcal{A}) \leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \frac{80q^2b^2}{2^n} + \frac{46qb(\ell+3)^2}{2^n},$$

by assuming $2qb \leq 2^{n/2-1}$ and $\ell+2 \leq 2^{n/4-0.5}$, where $\mathcal{B}$ is an adversary against the PRP security of the block cipher E that runs in time at most $t' = t + 2qb(\ell+3)t_E$ and makes at most $2qb(\ell+3)$ block cipher queries where t_E denotes the running time of E .

Proof. Following similar arguments as in the proof of Theorem 1, we can first replace the block cipher E_K with a random permutation $\pi \leftarrow \text{Perm}(n)$ and then replace the CMAC algorithm with a random function $f \leftarrow \text{Func}(\{0,1\}^*, \{0,1\}^n)$. We obtain

$$\text{Adv}_{\text{KDPL-CMAC}[E]}^{\text{volprf}}(\mathcal{A}) \leq \text{Adv}_E^{\text{prp}}(\mathcal{B}) + \frac{80q^2b^2}{2^n} + \frac{46qb(\ell+2)^2}{2^n} + \text{Adv}_{\text{KDPL-CMAC}[f]}^{\text{volprf}}(\mathcal{A}),$$

where $\mathcal{B}$ is an adversary against the PRP security of block cipher E , making at most $2qb(\ell + 3)$ queries and runs in times at most $t' = t + 2qb(\ell + 3)t_E$.

Next, we consider the advantage of the adversary $\mathcal{A}$ in distinguishing the key derivation function $\text{KDPL-CMAC}[f]$ based on a random function f from a variable output length random function. As shown in Fig. 9, for any query $M = A_0$ to $\text{KDPL-CMAC}[f]$, the inputs of the random function f to produce the keying material C are $A_1 \parallel 1 \parallel A_0, A_2 \parallel 2 \parallel A_0, \dots, A_b \parallel b \parallel A_0$ that are all distinct values. Hence, the outputs $S_1, S_2, \dots, S_b$ are independently random strings. The final output string C is a L -bit random string as it is the L -bit truncation from the concatenation of these strings. Similarly, for any two distinct queries M and M' , the inputs of the random function f to produce keying materials C and C' are all distinct values due to the use of counter i and the constraint $M \neq M'$. Hence, the two derived keying materials are independently random strings. Following similar argument, for any q queries, the corresponding derived keying materials are random strings and independent from each other. Therefore,

$$\text{Adv}_{\text{KDPL-CMAC}[f]}^{\text{volprf}}(\mathcal{A}) = 0 \quad .$$

COLLISION RESISTANCE. As we can see, for the case of n -bit derived keying material, the key derivation function KDPL-CMAC behaves exactly the same as KFB-CMAC . Hence, we can use the result of Theorem 7 to justify the collision resistance security of KDPL-CMAC that is stated as follows.

Theorem 13. *For any adversary $\mathcal{A}$ that makes at most p ideal-cipher queries to E and E^{-1} , we have*

$$\text{Adv}_{\text{KDPL-CMAC}}^{\text{coll}}(\mathcal{A}) \leq \frac{2p^2\ell + p(p+3)}{2^n} \quad ,$$

where ℓ is the maximum block length of a message to the key derivation function.

PREIMAGE RESISTANCE. Fix an image $T \in \{0, 1\}^n$. We say that the adversary finds a preimage against KDPL-CMAC if she finds a pair of (K, M) satisfying $\text{KDPL-CMAC}(K, M)[1 : n] = T$. The following theorem shows that KDPL-CMAC is preimage resistant. As for the n -bit derived keying material, KDPL-CMAC is the same as KFB-CMAC , the proof of this theorem is the same as that of Theorem 8.

Theorem 14. *For any adversary $\mathcal{A}$ that makes at most p ideal-cipher queries to E and E^{-1} , we have*

$$\text{Adv}_{\text{KDPL-CMAC}}^{\text{epre}}(\mathcal{A}) \leq \frac{4p}{2^n} + \frac{2p^2\ell}{2^n} \quad ,$$

where ℓ is the maximum block length of a query to the key derivation function.

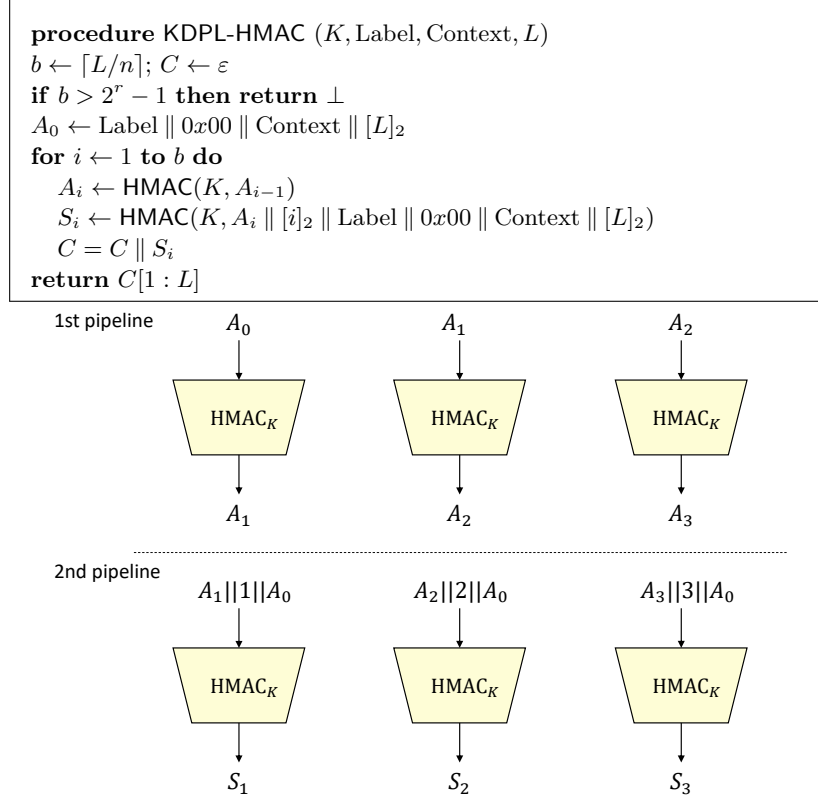


Fig. 10: The pseudocode definition of KDPL-HMAC in double-pipeline mode based on HMAC and its pictorial illustration for producing $3n$ -bit keying material $C = S_1 \parallel S_2 \parallel S_3$. The counter i is optional in KDPL-HMAC.

5.2 Security Analysis of KDPL-HMAC

In this subsection, we give analysis of the key derivation function KDPL-HMAC based on HMAC in double-pipeline mode. We prove that KDPL-HMAC is a secure volPRF with the bound $O(\frac{q^2 b^2}{2^n} + \frac{qb^2}{2^n})$. We show that KDPL-HMAC is collision resistant and preimage resistant with the bound $O(\frac{p^2}{2^n})$.

SCHEME DESCRIPTION. The key derivation function KDPL-HMAC is the same as KDPL-CMAC, except that the CMAC algorithm is replaced with the HMAC algorithm and the counter i becomes optional. The specification and pictorial illustration of KDPL-HMAC can be found in Fig. 10.

VOLPRF SECURITY. The following theorem shows that KDPL-HMAC is a secure volPRF by assuming h is a secure dual-PRF and $\bar{h}$ is a secure rka-PRF. The proof is done for the case when the counter i is not included as the input to HMAC. It can trivially works for the case when the counter i is included.

Theorem 15. *For any adversary $\mathcal{A}$ against the volPRF security of KDPL-HMAC that runs in time at most t , makes at most q queries, with each query being of block length at most ℓ and being of output block length at most b , we have*

$$\begin{aligned} \text{Adv}_{\text{KDPL-HMAC}}^{\text{volprf}}(\mathcal{A}) &\leq (\ell + 4) \text{Adv}_h^{\text{prf}}(\mathcal{A}_1) + \text{Adv}_{\bar{h}}^{\text{prf}}(\mathcal{A}_2) + \text{Adv}_{\Phi_{\text{zio}, e}, \bar{h}}^{\text{rkaprff}}(\mathcal{B}) \\ &\quad + \frac{2qb(2qb - 1)}{2^{n+1}} + \frac{qb^2}{2^n} . \end{aligned}$$

Adversaries $\mathcal{A}_1$ and $\mathcal{A}_2$ are against the PRF security of h and $\bar{h}$ respectively, where $\mathcal{A}_1$ makes at most $2qb$ queries and $\mathcal{A}_2$ makes one query. Adversary $\mathcal{B}$ makes two queries. The running times of adversaries $\mathcal{A}_1, \mathcal{A}_2$ and $\mathcal{B}$ are about the same as that of $\mathcal{A}$.

Proof. Firstly, we replace the HMAC algorithm in KDPL-HMAC with a random function $f \leftarrow \text{Func}(\{0, 1\}^* \times \{0, 1\}^*, \{0, 1\}^n)$ and denote the resulting key derivation function by $\text{KDPL-HMAC}[f]$. Following the result of [1, Theorem 8], we obtain

$$\begin{aligned} \text{Adv}_{\text{KDPL-HMAC}}^{\text{volprf}}(\mathcal{A}) &\leq (\ell + 4) \text{Adv}_h^{\text{prf}}(\mathcal{A}_1) + \text{Adv}_{\bar{h}}^{\text{prf}}(\mathcal{A}_2) + \text{Adv}_{\Phi_{\text{zio}, e}, \bar{h}}^{\text{rkaprff}}(\mathcal{B}) \\ &\quad + \frac{2qb(2qb - 1)}{2^{n+1}} + \text{Adv}_{\text{KDPL-HMAC}[f]}^{\text{volprf}}(\mathcal{A}) , \end{aligned}$$

where $\mathcal{A}_1$ is an adversary against the PRF security of h that makes at most $2qb$ queries, $\mathcal{A}_2$ is an adversary against the PRF security of $\bar{h}$ that makes one query, and $\mathcal{B}$ is an adversary against the rka-PRF security of $\bar{h}$ that makes two queries, the time complexity of who are all about the same as that of $\mathcal{A}$.

Next, we analyze the volPRF security of $\text{KDPL-HMAC}[f]$. For the i -th query M_i to $\text{KDPL-HMAC}[f]$, the inputs of random function f to produce strings $S_1^i, \dots, S_b^i$ are $A_1^i \parallel A_0^i, \dots, A_b^i \parallel A_0^i$ where $A_0^i = M_i$. If A_j^i is different from $A_1^i, \dots, A_{j-1}^i$, then the input $A_j^i \parallel A_0^i$ of random function f is fresh. Hence, in this case the output S_j^i will be a random string. Denote by $\text{bad}_{i,j}$ the event that at the i -th query, A_j^i collides with previous $A_1^i, \dots, A_{j-1}^i$. For two different queries M_i and M_j to $\text{KDPL-HMAC}[f]$, the inputs of random function f regarding M_i are different from those inputs of random function f regarding M_j as their inputs contain two different strings M_i and M_j . Denote by $\text{bad} = \bigvee_{i=1}^q (\bigvee_{j=1}^b \text{bad}_{i,j})$ the union of these events $\text{bad}_{i,j}$ for $1 \leq i \leq q$ and $1 \leq j \leq b$. If the event bad does not happen, then the outputs of $\text{KDPL-HMAC}[f]$ are random strings that are the same as the outputs of a variable output length random function. Hence, by the fundamental lemma of game-playing technique [5], we have

$$\text{Adv}_{\text{KDPL-HMAC}[f]}^{\text{volprf}}(\mathcal{A}) \leq \Pr[\text{bad}] .$$

We now bound the probability of event bad . The occurrence of event $\text{bad}_{i,j}$ requires either as an input A_{j-1}^i hits previous inputs of random function f that are $A_0^i, \dots, A_{j-2}^i$, or as an output A_j^i hits previous outputs of random

function f that are $A_1^i, \dots, A_{j-1}^i$. Hence, conditioned on previous bad events $\text{bad}_{i,1}, \dots, \text{bad}_{i,j-1}$ do not happen, we have

$$\Pr[\text{bad}_{i,j} \mid \overline{\text{bad}}_{i,1} \wedge \dots \wedge \overline{\text{bad}}_{i,j-1}] \leq \frac{2(j-1)}{2^n}.$$

Therefore,

$$\begin{aligned} \Pr[\text{bad}] &= \Pr[\bigvee_{i=1}^q (\bigvee_{j=1}^b \text{bad}_{i,j})] \\ &\leq \sum_{i=1}^q \sum_{j=2}^b \Pr[\text{bad}_{i,j} \mid \overline{\text{bad}}_{i,1} \wedge \dots \wedge \overline{\text{bad}}_{i,j-1}] \\ &\leq \sum_{i=1}^q \sum_{j=1}^b \frac{2(j-1)}{2^n} \\ &\leq \frac{qb^2}{2^n} \end{aligned}$$

that concludes the proof.

COLLISION RESISTANCE. Assuming that the compression function $h : \{0,1\}^n \times \{0,1\}^d \rightarrow \{0,1\}^n$ is a random oracle, the following theorem shows that KDPL-HMAC is collision resistant. The proof is similar to the one of Theorem 4, and thus is omitted. Similar to KCTR-HMAC, we can mount collision attack against KDPL-HMAC when the key is of arbitrary length.

Theorem 16. *Suppose that the key length of KDPL-HMAC is fixed and less than $d-1$ bits. For any adversary $\mathcal{A}$ that makes at most p queries to the compression function h , we have*

$$\text{Adv}_{\text{KDPL-HMAC}}^{\text{coll}}(\mathcal{A}) \leq \frac{13p^2}{2^n}.$$

PREIMAGE RESISTANCE. Assuming that the compression function $h : \{0,1\}^n \times \{0,1\}^d \rightarrow \{0,1\}^n$ is a random oracle, the following theorem shows KDPL-HMAC is preimage resistant. The proof relies on the indifferntiality of HMAC which is similar to the proof of Theorem 11, and thus is omitted.

Theorem 17. *Suppose that the key length of KFB-HMAC is fixed and less than $d-1$ bits. For any adversary $\mathcal{A}$ that makes at most p queries to the compression function h , we have*

$$\text{Adv}_{\text{KDPL-HMAC}}^{\text{epre}}(\mathcal{A}) \leq \frac{13p^2}{2^n}.$$

6 Concluding Remarks

In this article, we give a comprehensive security analysis of key derivation functions using pseudorandom functions in NIST SP 800-108 [11]. Based on our analyses, KCTR-CMAC may not be a good choice in general as a KDF as it is

vulnerable to the collision attack. While for other KDFs, including KFB-CMAC, KDPL-CMAC, KCTR-HMAC, KFB-HMAC, and KDPL-HMAC (KDFs based on HMAC should use a key of fixed length that is less than $d - 1$ bits), they are all basically good as a KDF, as all of them are volPRF, collision resistant, and preimage resistant. Overall, we believe these results contribute to the community for deeper understanding of the current version of standard NIST SP 800-108. We personally suggest that the standard should be revised for a stronger security, especially regarding the algorithm KCTR-CMAC as it is not collision resistant (or not context binding) as required by this standard.

References

1. M. Backendal, M. Bellare, F. Günther, and M. Scarlata. When messages are keys: Is HMAC a dual-prf? In *Advances in Cryptology - CRYPTO 2023 - 43rd Annual International Cryptology Conference, CRYPTO 2023, Santa Barbara, CA, USA, August 20-24, 2023, Proceedings, Part III*, pages 661–693, 2023.
2. E. Barker, L. Chen, R. Davis, et al. Recommendation for key-derivation methods in key-establishment schemes. *NIST Special Publication*, 800:56C, 2018.
3. M. Bellare, R. Canetti, and H. Krawczyk. Keying hash functions for message authentication. In *Advances in Cryptology - CRYPTO '96, 16th Annual International Cryptology Conference, Santa Barbara, California, USA, August 18-22, 1996, Proceedings*, pages 1–15, 1996.
4. M. Bellare and T. Kohno. A theoretical treatment of related-key attacks: Rka-prps, rka-prfs, and applications. In *Advances in Cryptology - EUROCRYPT 2003, International Conference on the Theory and Applications of Cryptographic Techniques, Warsaw, Poland, May 4-8, 2003, Proceedings*, pages 491–506, 2003.
5. M. Bellare and P. Rogaway. The security of triple encryption and a framework for code-based game-playing proofs. In *Advances in Cryptology - EUROCRYPT 2006, 25th Annual International Conference on the Theory and Applications of Cryptographic Techniques, St. Petersburg, Russia, May 28 - June 1, 2006, Proceedings*, pages 409–426, 2006.
6. G. Bertoni, J. Daemen, M. Peeters, and G. V. Assche. On the indistinguishability of the sponge construction. In *Advances in Cryptology - EUROCRYPT 2008, 27th Annual International Conference on the Theory and Applications of Cryptographic Techniques, Istanbul, Turkey, April 13-17, 2008. Proceedings*, pages 181–197, 2008.
7. R. Bhaumik, B. Chakraborty, W. Choi, A. Dutta, J. Govinden, and Y. Shen. The committing security of macs with applications to generic composition. In *Advances in Cryptology - CRYPTO 2024 - 44th Annual International Cryptology Conference, Santa Barbara, CA, USA, August 18-22, 2024, Proceedings, Part IV*, pages 425–462, 2024.
8. S. Chattopadhyay, A. Jha, and M. Nandi. Towards tight security bounds for omac, XCBC and TMAC. In *Advances in Cryptology - ASIACRYPT 2022 - 28th International Conference on the Theory and Application of Cryptology and Information Security, Taipei, Taiwan, December 5-9, 2022, Proceedings, Part I*, pages 348–378, 2022.
9. L. Chen. Recommendation for key derivation using pseudorandom functions - nist sp 800-108. 2008.
10. L. Chen. Recommendation for key derivation using pseudorandom functions - nist sp 800-108r1. 2022.

11. L. Chen. Recommendation for key derivation using pseudorandom functions - nist sp 800-108r1-upd1. 2024.
12. Y. Dodis, T. Ristenpart, J. P. Steinberger, and S. Tessaro. To hash or not to hash again? (in)differentiability results for H₂ and HMAC. In *Advances in Cryptology - CRYPTO 2012 - 32nd Annual Cryptology Conference, Santa Barbara, CA, USA, August 19-23, 2012. Proceedings*, pages 348–366, 2012.
13. M. J. Dworkin. Recommendation for block cipher modes of operation: The cmac mode for authentication. 2016.
14. T. Iwata and K. Kurosawa. OMAC: one-key CBC MAC. In *Fast Software Encryption, 10th International Workshop, FSE 2003, Lund, Sweden, February 24-26, 2003, Revised Papers*, pages 129–153, 2003.
15. J. Kelsey, S.-j. Chang, and R. Perlner. Nist special publication 800–185: sha-3 derived functions: cshake, kmac, tuplehash and parallelhash. *National Institute of Standards and Technology, Gaithersburg, MD, Tech. Rep*, 2016.
16. J. Krämer, P. Struck, and M. Weishäupl. Committing AE from sponges security analysis of the NIST LWC finalists. *IACR Trans. Symmetric Cryptol.*, 2024(4):191–248, 2024.
17. H. Krawczyk. Cryptographic extraction and key derivation: The HKDF scheme. In *Advances in Cryptology - CRYPTO 2010, 30th Annual Cryptology Conference, Santa Barbara, CA, USA, August 15-19, 2010. Proceedings*, pages 631–648, 2010.
18. J. Mattsson. Public comments on sp 800-38c. 2024.
19. M. Nandi. Improved security analysis for OMAC as a pseudorandom function. *J. Math. Cryptol.*, 3(2):133–148, 2009.
20. P. Rogaway and T. Shrimpton. Cryptographic hash-function basics: Definitions, implications, and separations for preimage resistance, second-preimage resistance, and collision resistance. In *Fast Software Encryption, 11th International Workshop, FSE 2004, Delhi, India, February 5-7, 2004, Revised Papers*, pages 371–388, 2004.
21. M. Stäuble. Actually good encryption? confusing users by changing nonces. *Semester project, Department of Computer Science, ETH Zürich*, page 8, 2022.